Evil PLC Attack

Weaponizing PLCs

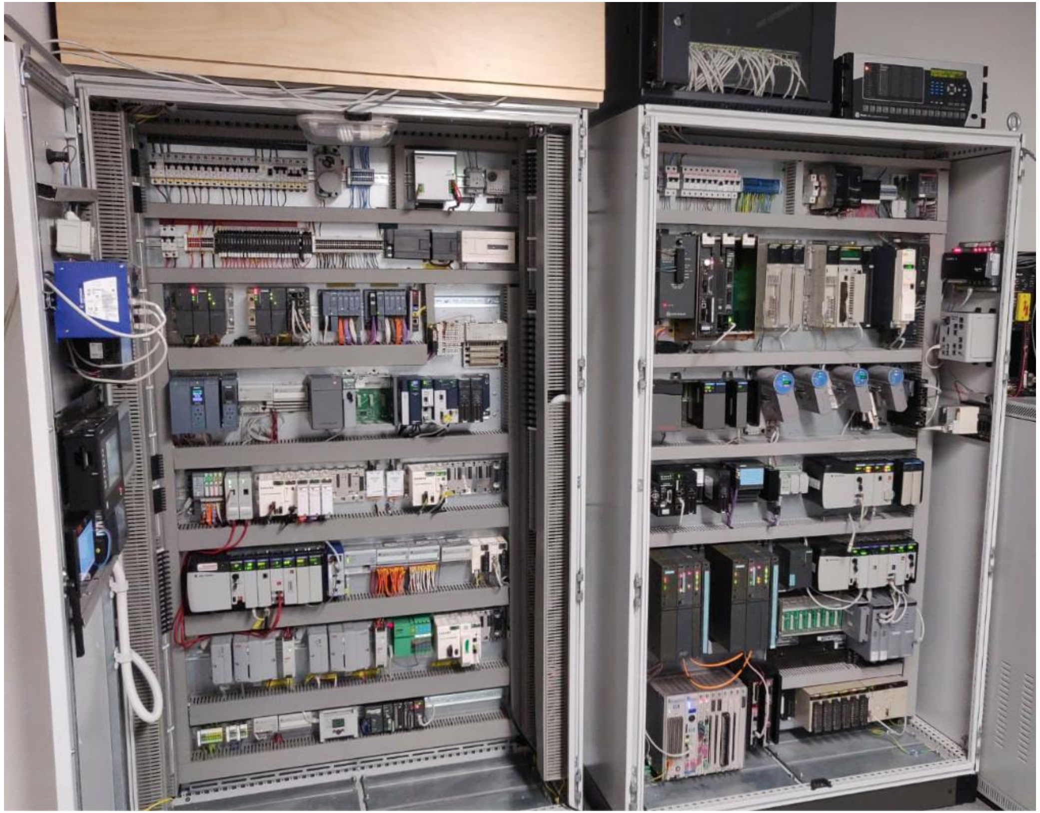
Who are we?

- **Sharon Brizinov** @ T82, Claroty Research
- Pwn2Own, DEFCON blackbadge, mostly breaking PLCs
- **Special thanks** to Mashav Sapir, Uri Katz, Noam Moshe, Amir Preminger

Agenda

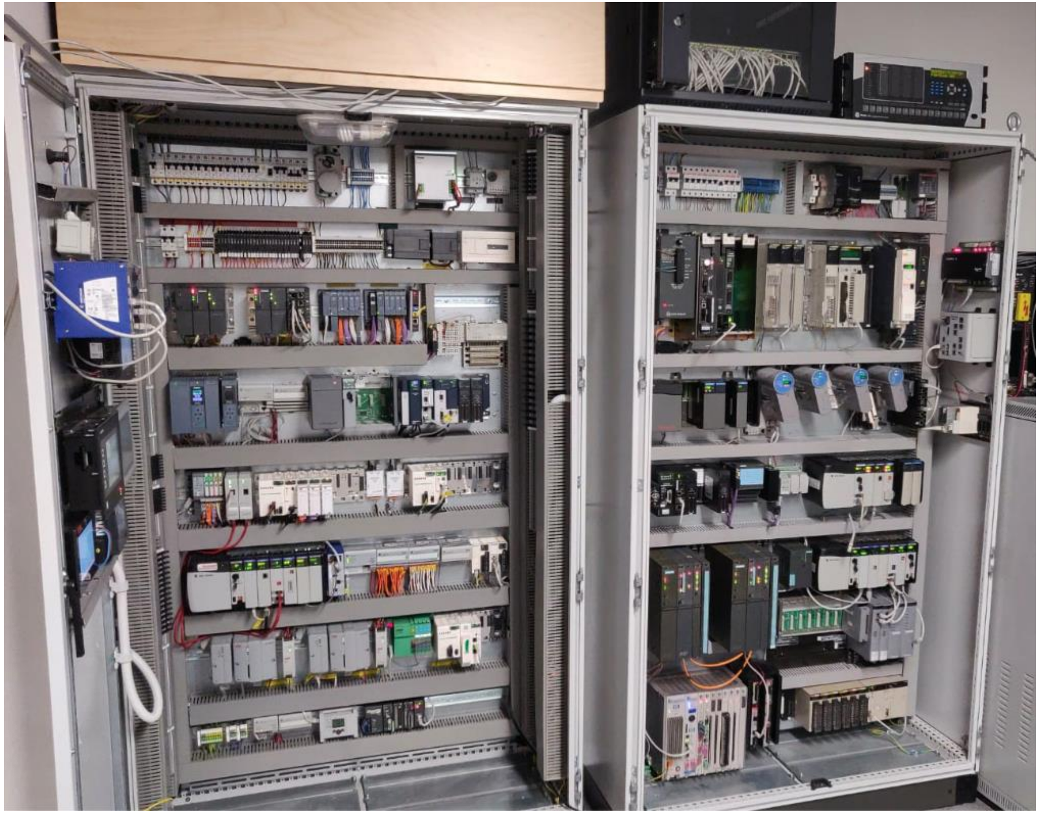
- **Motivation**
- PLC Download & Upload Procedures
- Evil PLC Attack

Story Time



Story Time

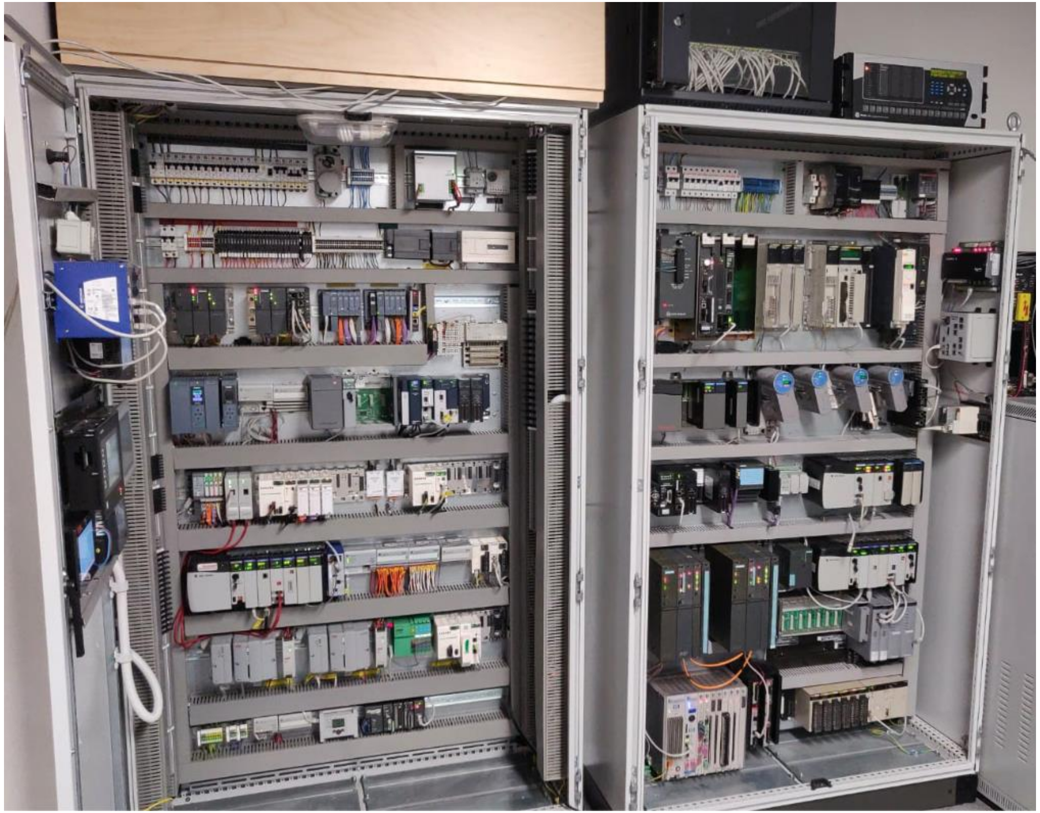
- We have a cool lab



Story Time

Internet

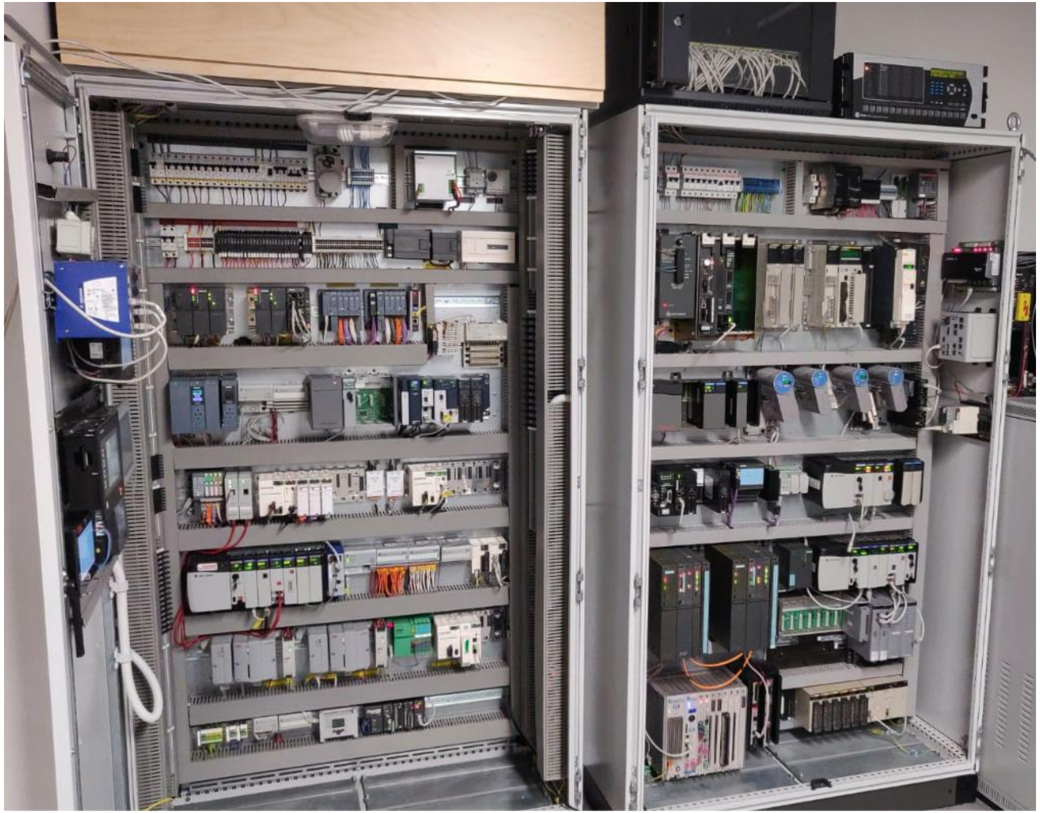
- We have a cool lab
- Let’s expose some PLC on the internet



Story Time

Internet

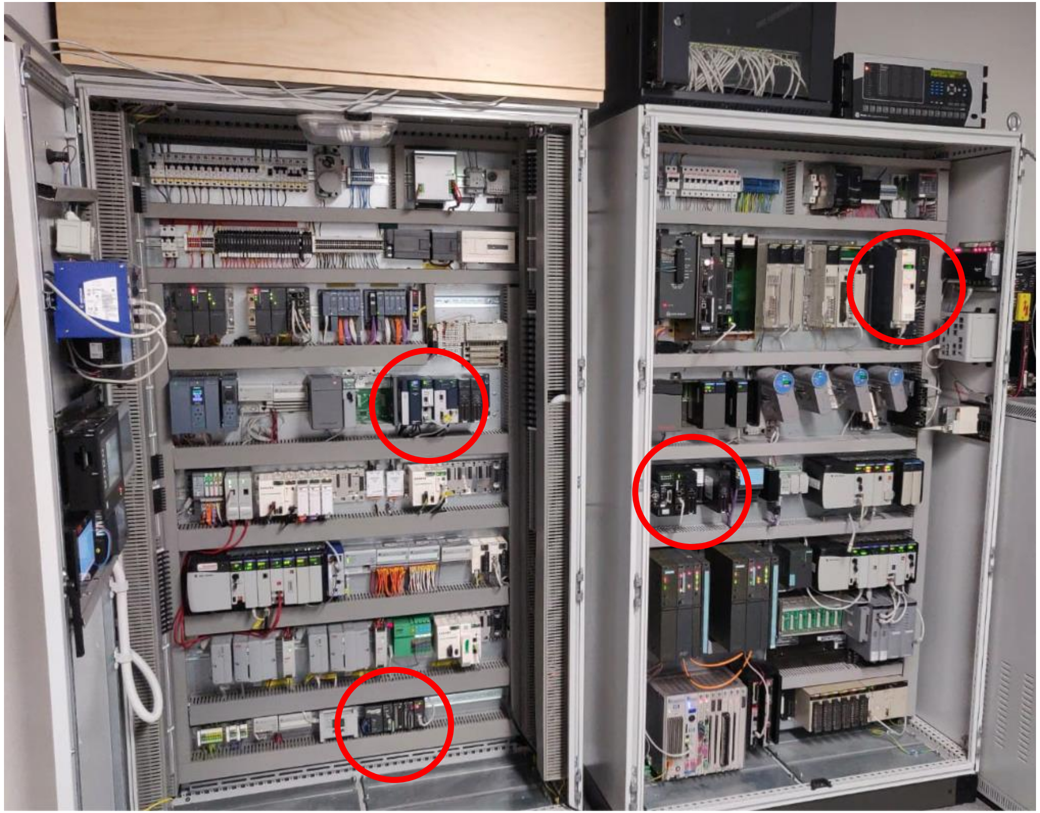
- We have a cool lab
- Let’s expose some PLC on the internet
- YOLO



Story Time

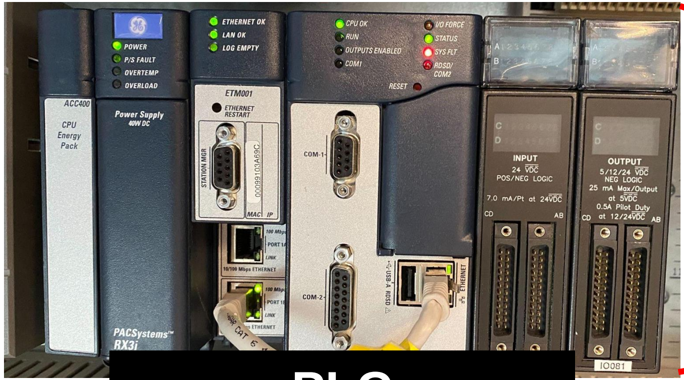
Internet

- We have a cool lab
- Let’s expose some PLC on the internet
- YOLO



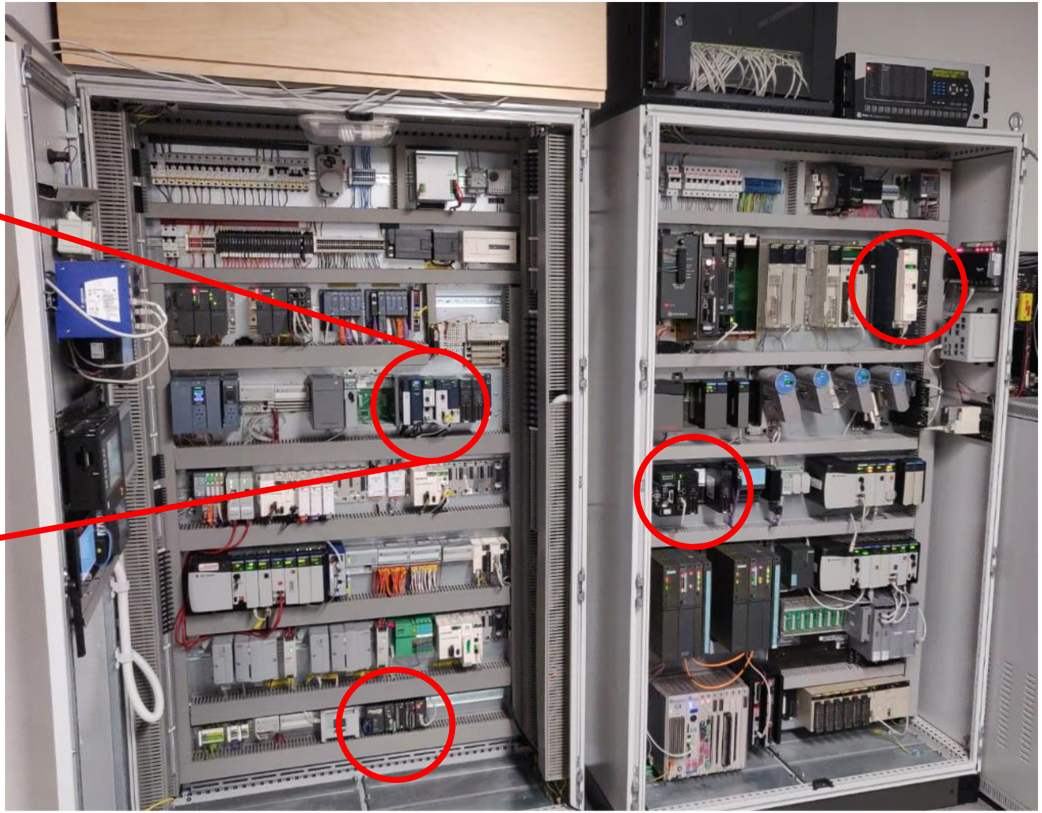
Story Time

Internet

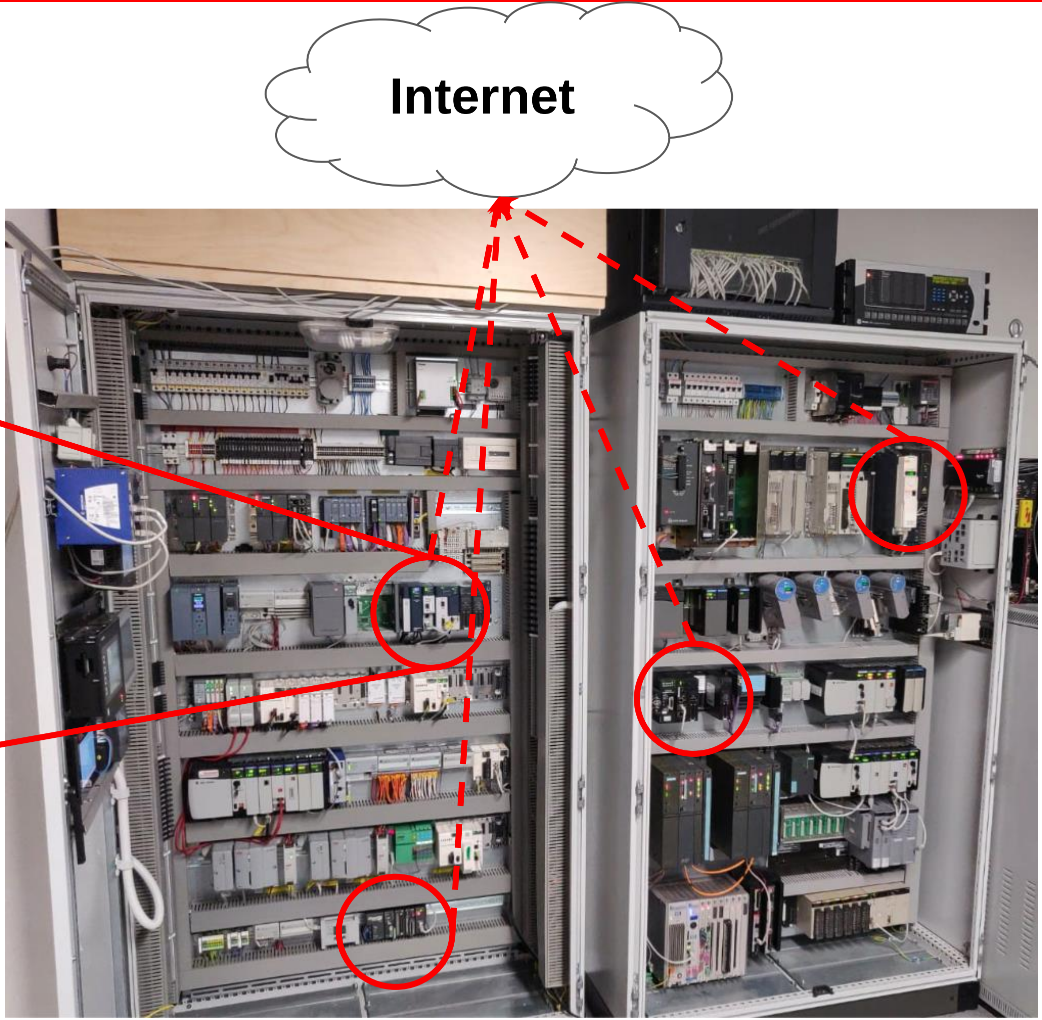


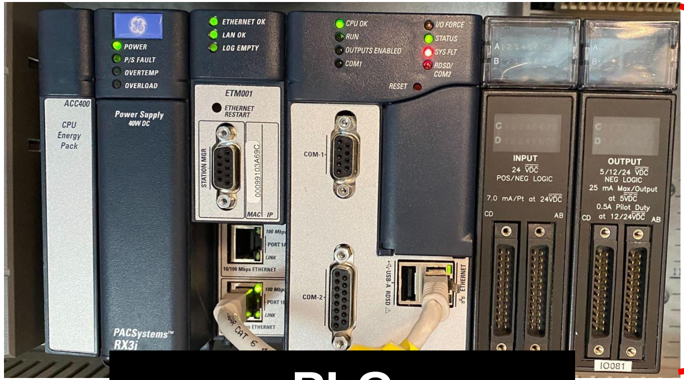
PLC

~~GE~~ Emerson rx3i



Story Time





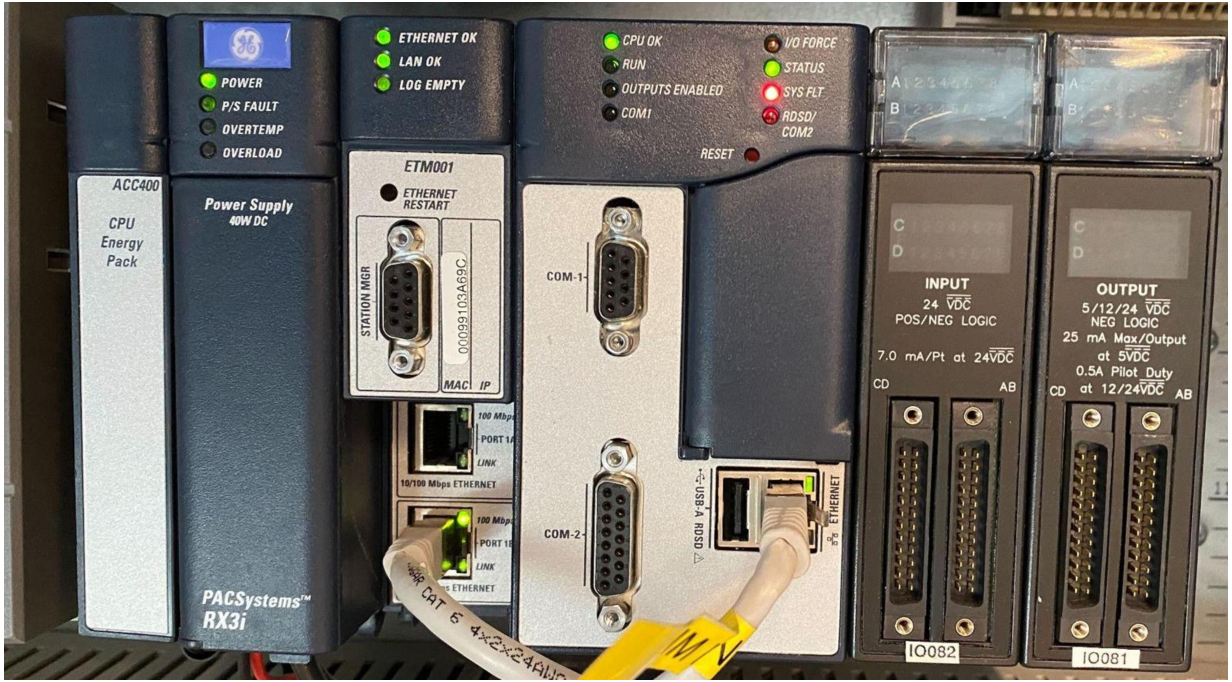
PLC

~~GE~~ Emerson rx3i


THREE
WEEKS LATER

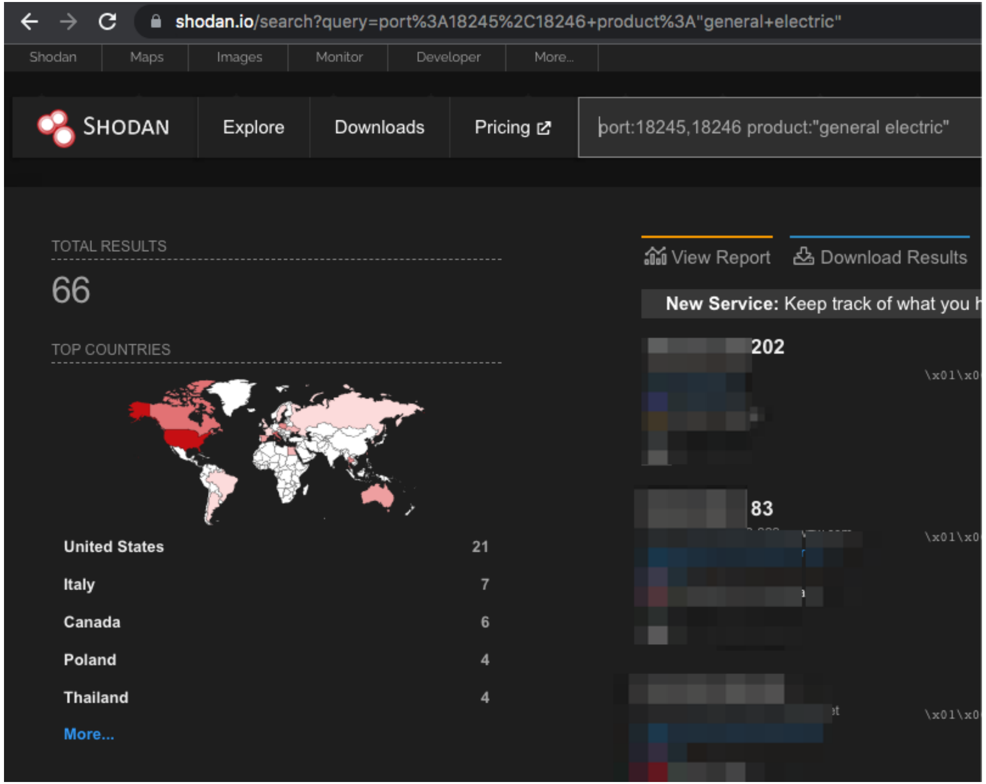
Experiment

- We've been hacked (OT style)!



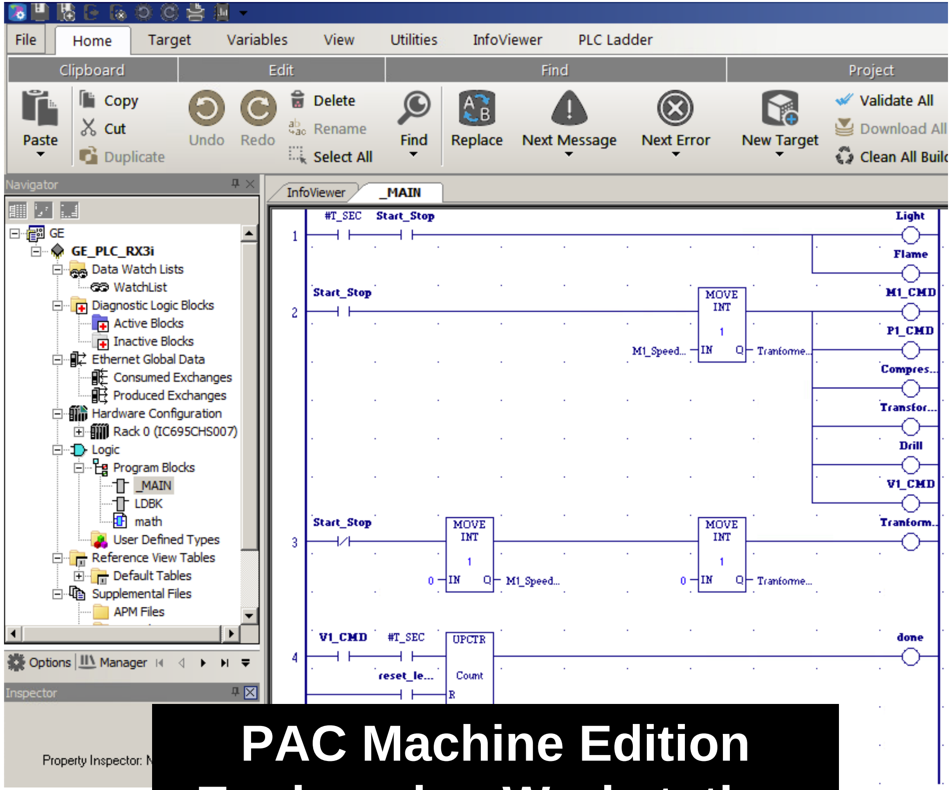
Experiment

- We've been hacked (OT style)!
- Highly sophisticated hacking group



Experiment

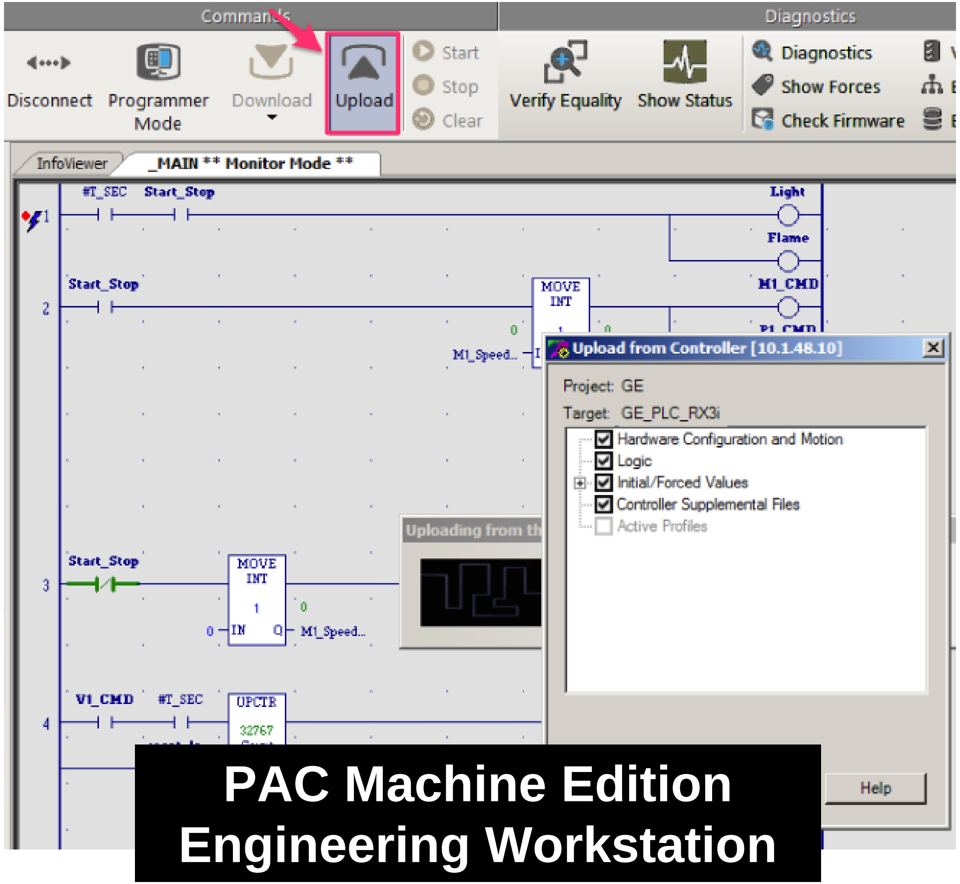
- We've been hacked (OT style)!
- Highly sophisticated hacking group
- Used the vendor's engineering workstation



PAC Machine Edition Engineering Workstation

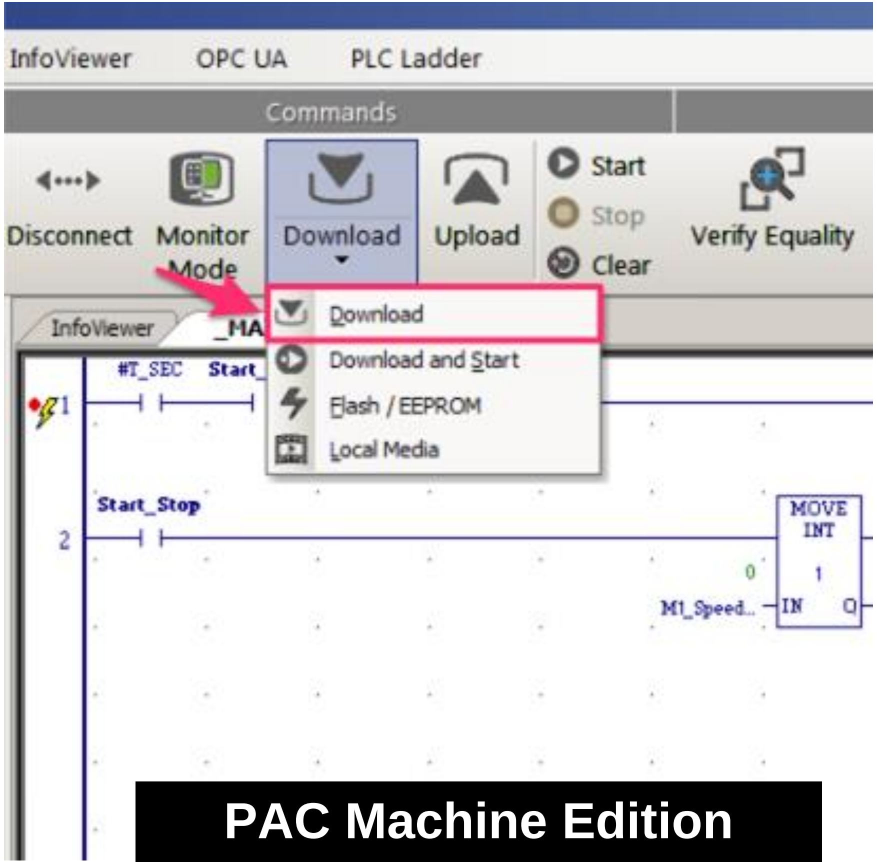
Experiment

- We've been hacked (OT style)!
- Highly sophisticated hacking group
- Used the vendor's engineering workstation
- To change our PLC's logic



Experiment

- We've been hacked (OT style)!
- Highly sophisticated hacking group
- Used the vendor's engineering workstation
- To change our PLC's logic



PAC Machine Edition Engineering Workstation

Experiment

- We’ve been hacked (OT style)!
- Highly sophisticated hacking group
- Used the vendor’s engineering workstation
- To change our PLC’s logic

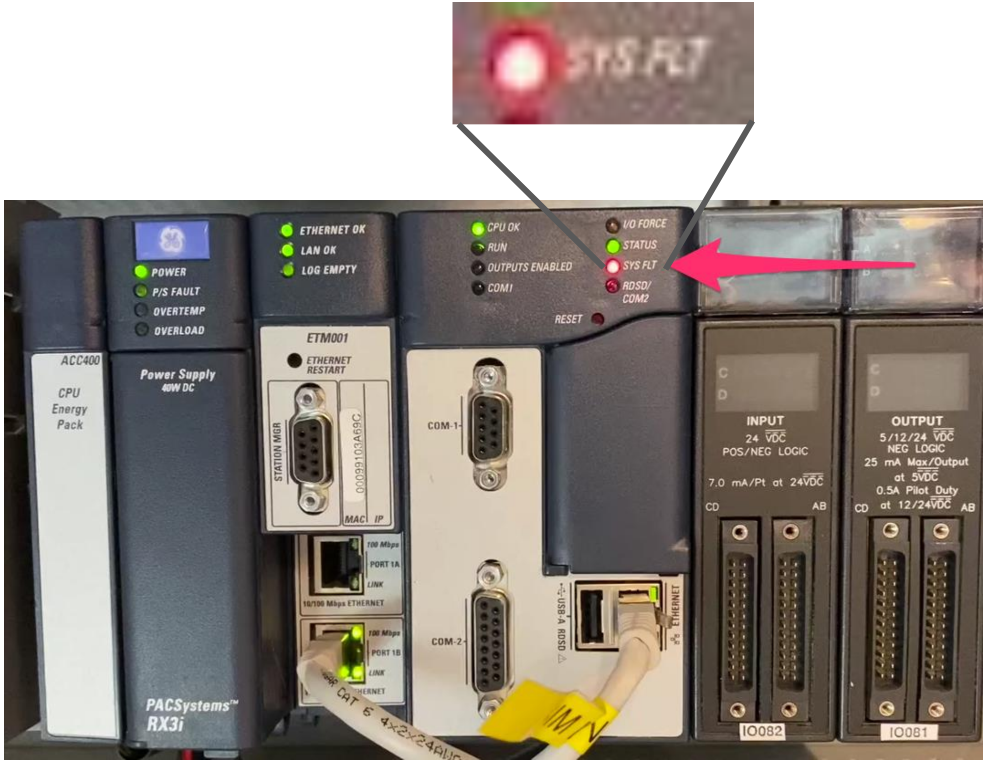
Experiment

- We’ve been hacked (OT style)!
- Highly sophisticated hacking group
- Used the vendor’s engineering workstation
- To change our PLC’s logic

What the attackers think happened

Experiment

- We’ve been hacked (OT style)!
- Highly sophisticated hacking group
- Used the vendor’s engineering workstation
- To change our PLC’s logic

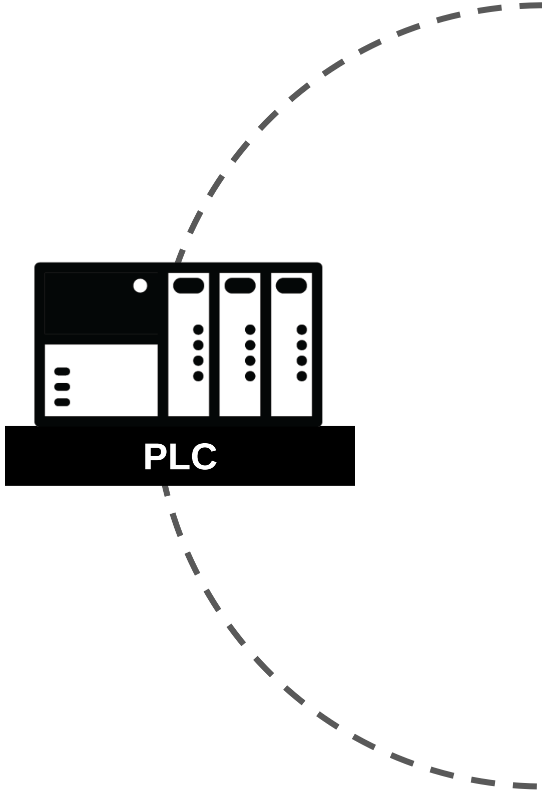


What really happened

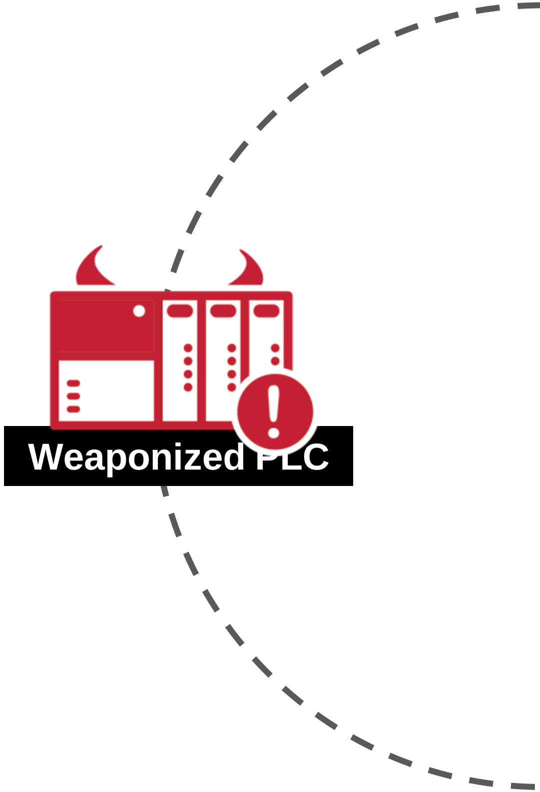
The best motivation is

REVENGE

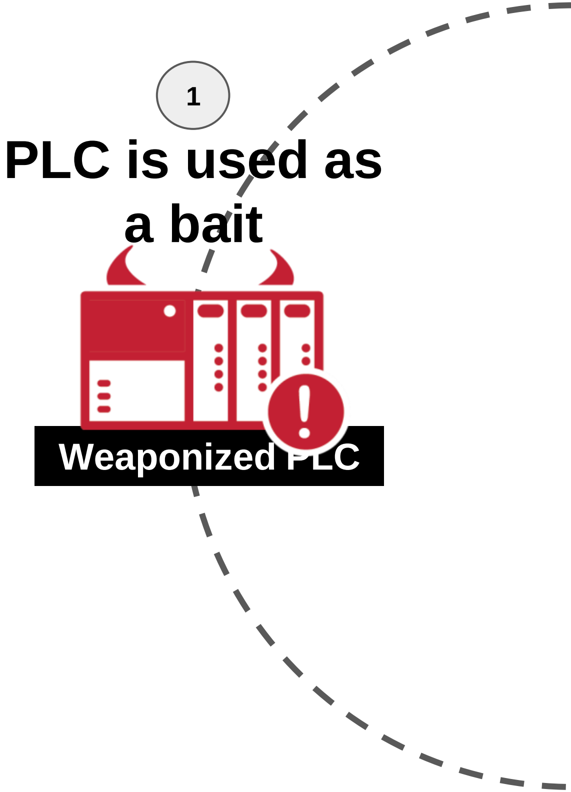
Goal: weaponize the PLC



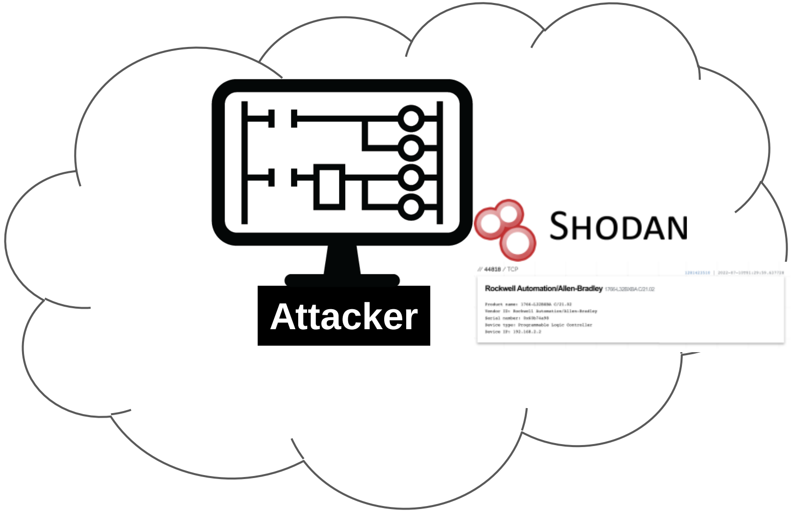
Goal: weaponize the PLC



Goal: weaponize the PLC

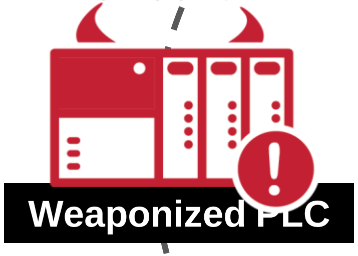


Goal: weaponize the PLC

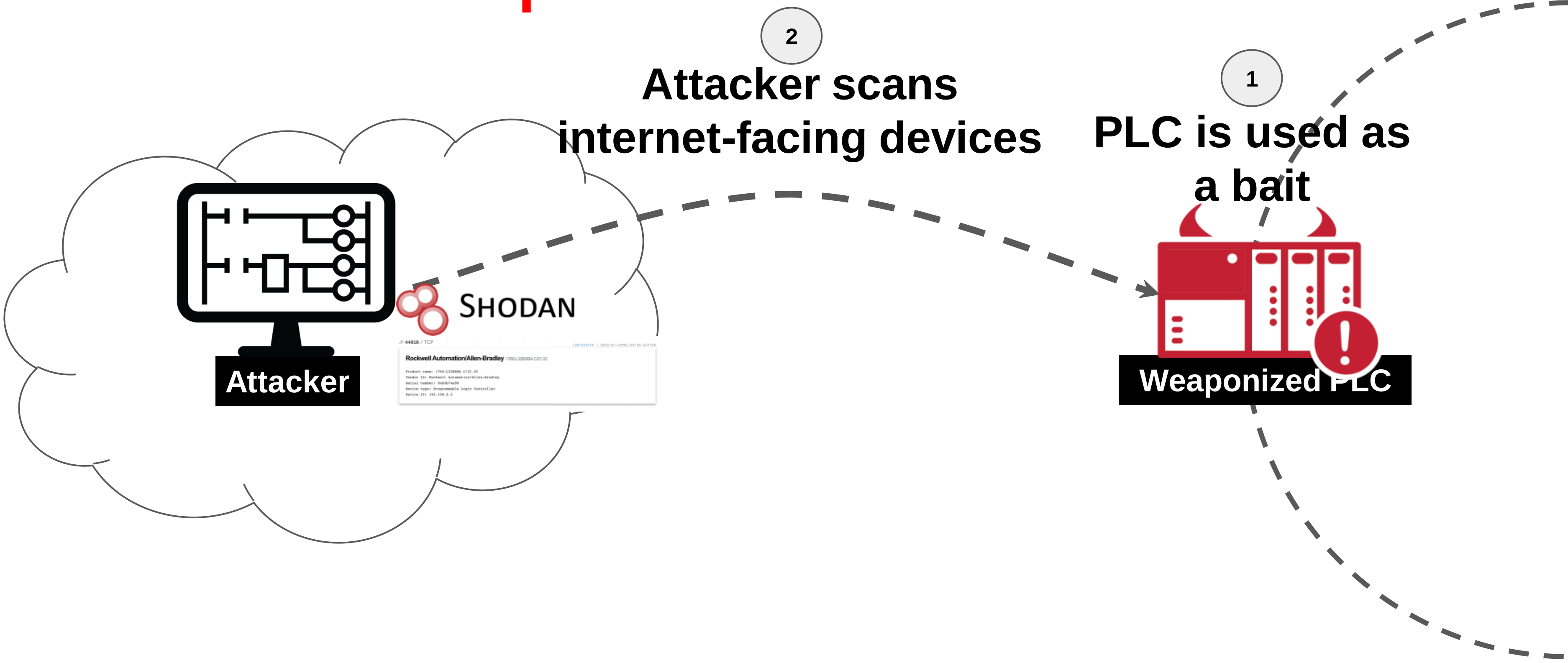


1

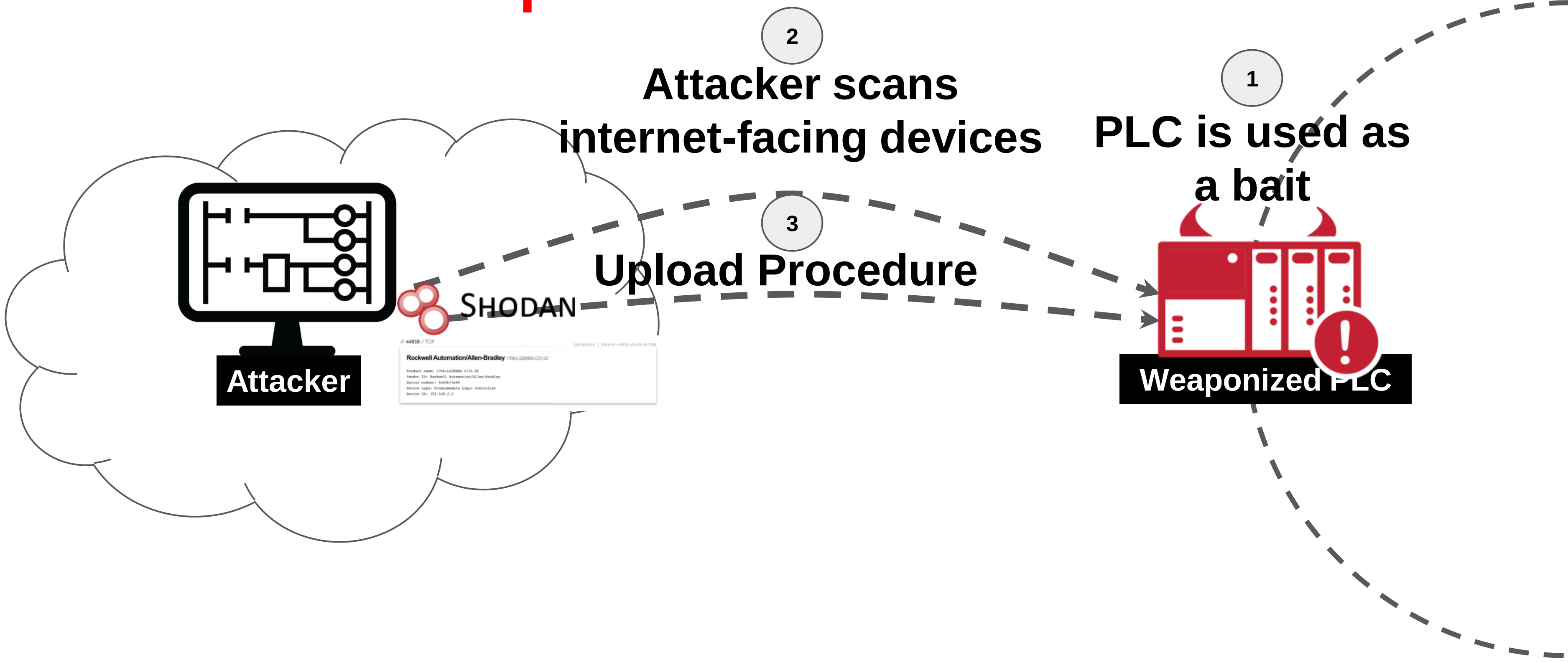
PLC is used as a bait



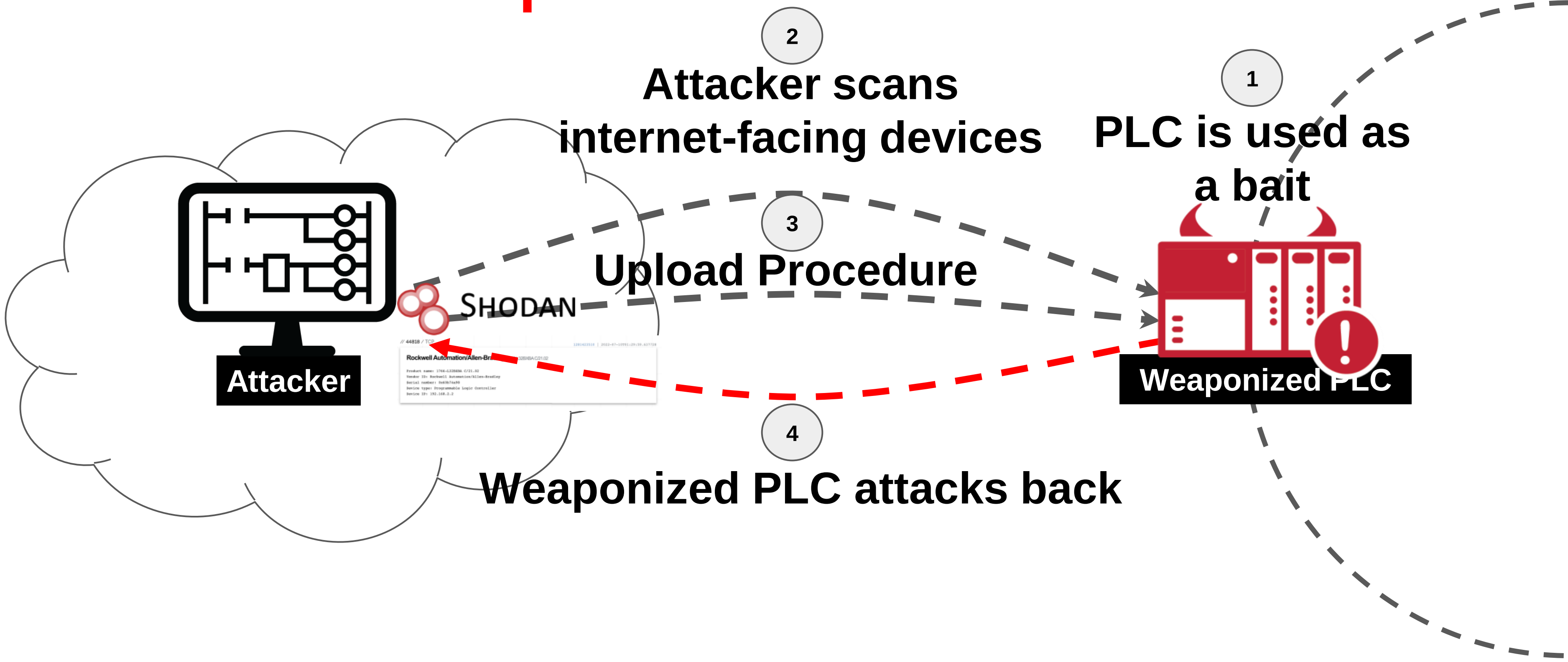
Goal: weaponize the PLC



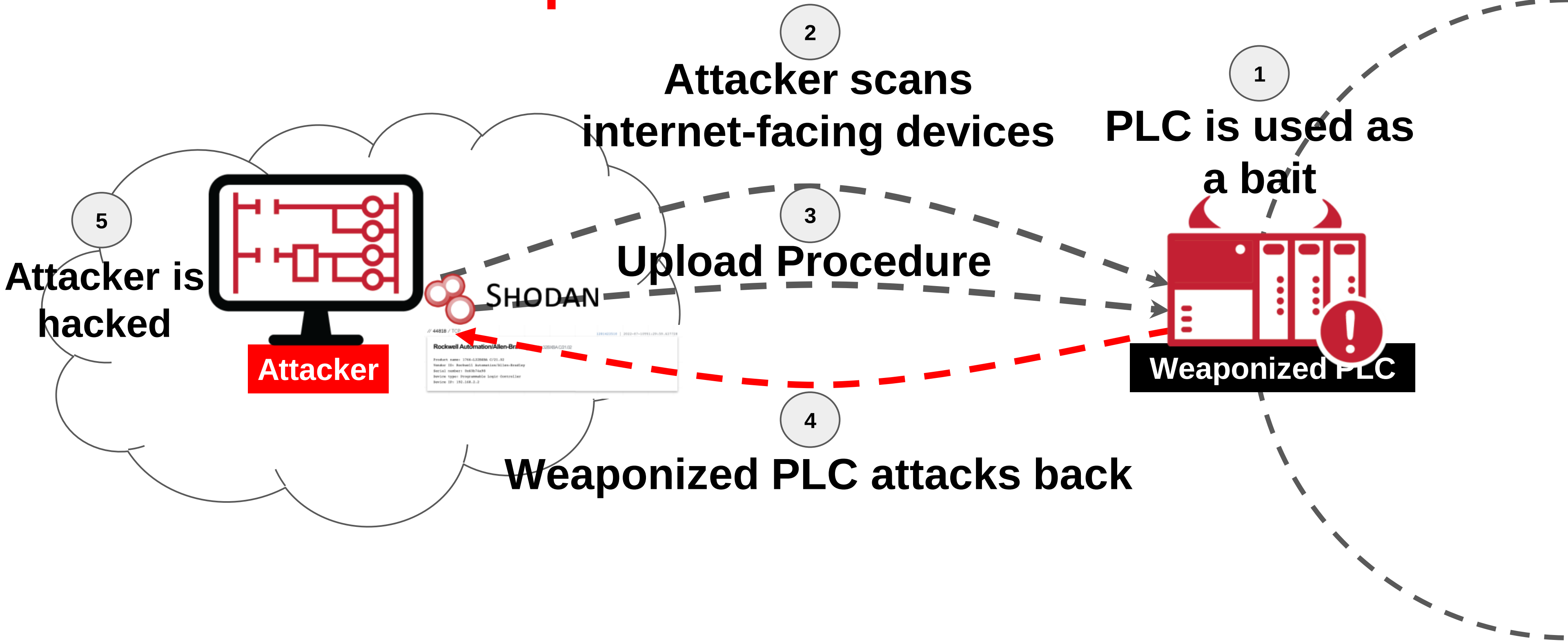
Goal: weaponize the PLC



Goal: weaponize the PLC



Goal: weaponize the PLC

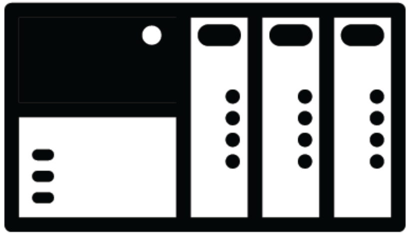


Agenda

- Motivation
- **PLC Download & Upload Procedures**
- Evil PLC Attack

Programmable Logic Controller

Control and Automate a Physical Process



PLC

Temperature Sensor

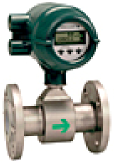
VFD (Variable Frequency Drive)

Pumps

Motoros

Pressure Transmitters

Flow Meter

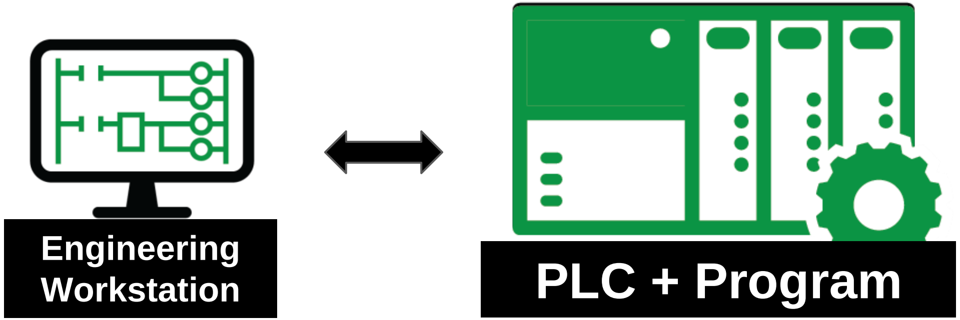


Valve Actuator

Field Devices: Sensors, Actuators

Programmable Logic Controller

Control and Automate a Physical Process



Temperature Sensor

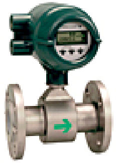
VFD (Variable Frequency Drive)

Pumps

Motoros

Pressure Transmitters

Flow Meter



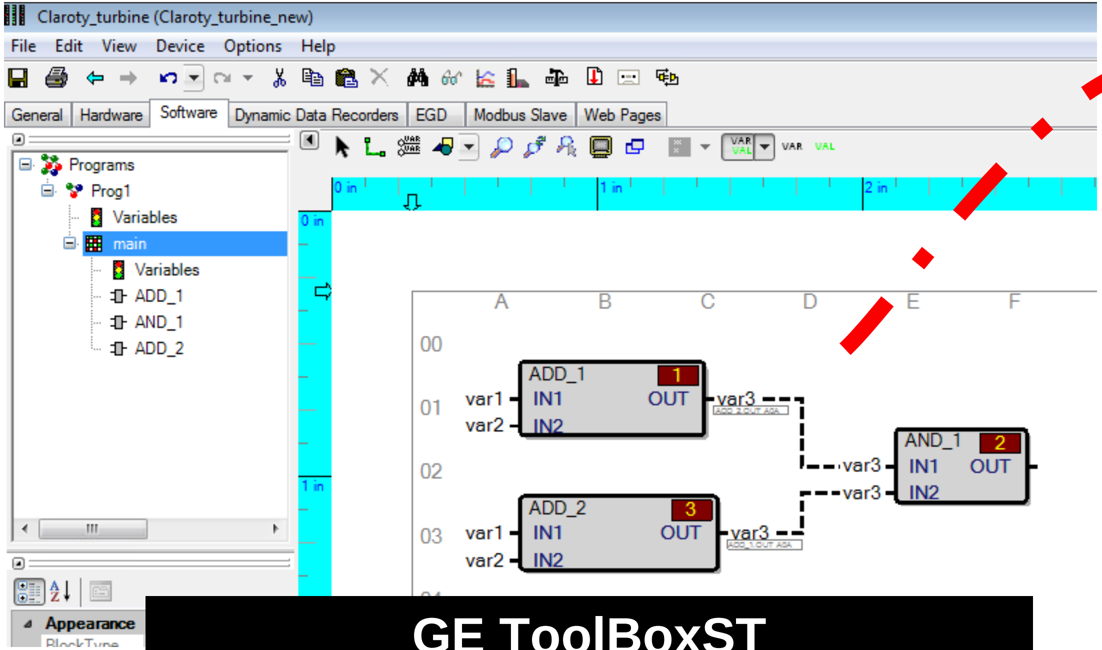
Valve Actuator

Field Devices: Sensors, Actuators

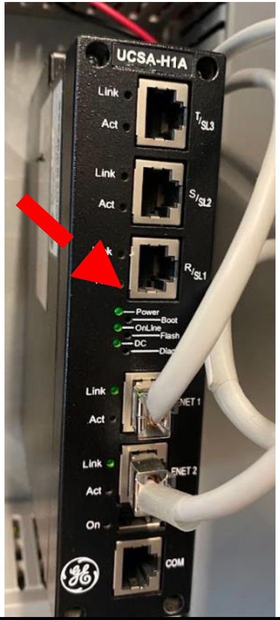
PLC Logic Transfer

Example: GE Mark VIe Platform

Logic



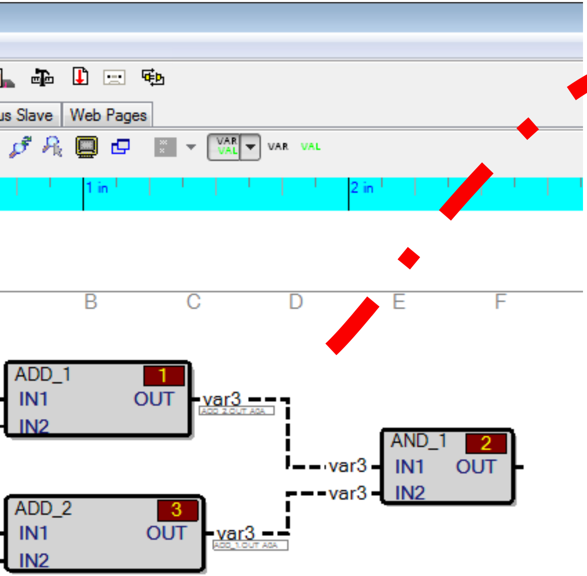
GE ToolBoxST
Engineering Workstation



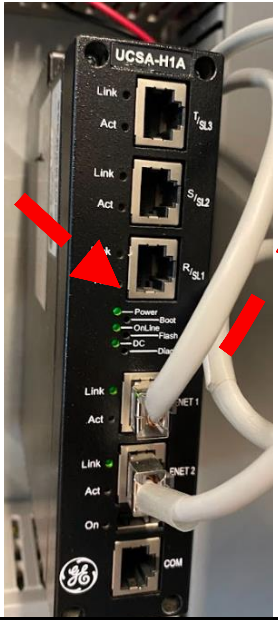
Mark VIe
IS220UCSAH1A

PLC Logic Transfer

Logic



ToolBoxST
ing Workstation



Mark VIe
IS220UCSAH1A

Physical Process

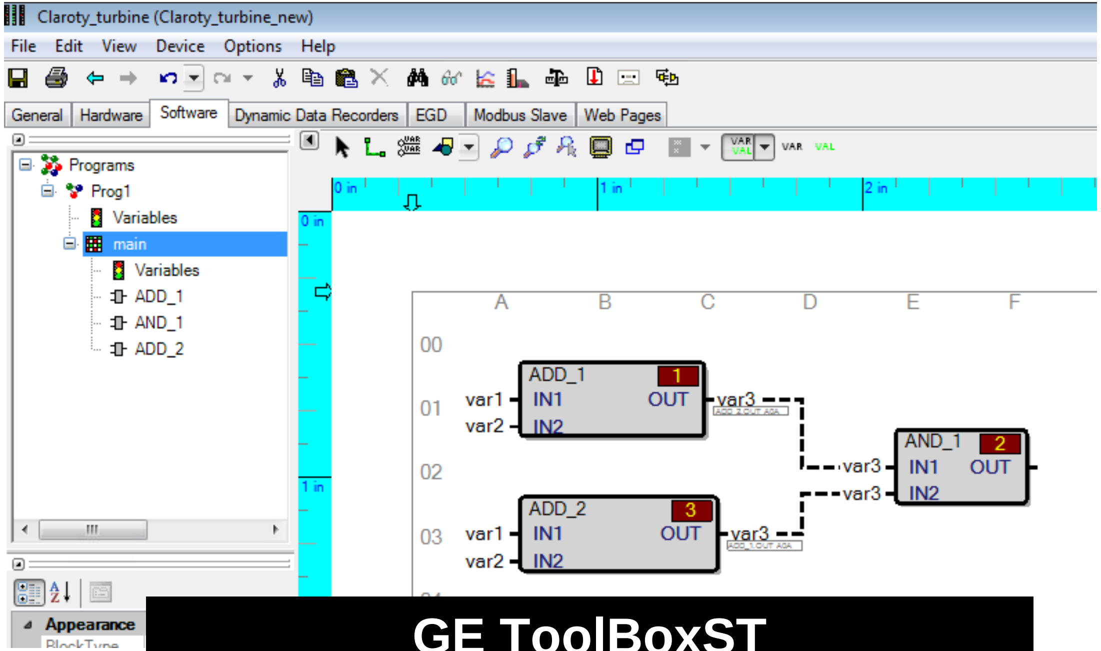
PLC Logic Transfer

DEVELOP

PLC code, or textual code, written in either LD, ST, or FBD languages.

IEC 61131-3
Source Code

PLC Logic Transfer



GE ToolBoxST
Block Diagram Logic

PLC Logic Transfer

_Prog1.xml

```
<?xml version="1.0" encoding="utf-8"?>
<?GeCssClass type="GeCss.Config.Blockware.Programme, ControllerBlockwareConfig" Version="V04.07.05C"?>
<Program Name="Prog1" IncrementalBuildState="None">
    <TopUserBlock Name="main" BlockType="" Version="V01.00.00A" Category="User Block" DiagramXML="BCD000017803oxxBBZmFTZElLs/bAAAA/169A
        <Heartbeat Name="_Heartbeat" Description="Task Heartbeat" Value="0" DataType="UINT" Address="06000013" Usage="Output" />
        <Enable Name="_Enable" Description="Task Enable" Value="True" Scope="Global" DataType="BOOL" Address="0100002E" GlobalNamePrefi
        <BlockCPUTicks Name="_BlockCPUTicks" Description="The number of CPU ticks it took to execute the user block." Value="0" DataTyp
        <F72188310901404A>AAAEBBmQ/FBiH1Yf2JOwGE/eaGCGwBSuYKw7u7F7mr6/Gar9yKZJwf8gx8XK1HZiQcGniCm+hXL+WocE3QoWBbsLNKzeVX/rCMdKn4CeNBpP6
        <Pin Name="var1" Value="10" DataType="REAL" Access="ReadWrite" PreviousInitialValue="0" Address="04000010" Usage="Input" />
        <Pin Name="var2" Value="15" DataType="REAL" Access="ReadWrite" PreviousInitialValue="0" Address="04000011" Usage="Input" />
        <Pin Name="var3" Value="0" DataType="REAL" Access="ReadWrite" Address="04000012" Usage="Output" />
        <Block Name="ADD_1" BlockType="ADD" BlockDataType="REAL" BlockLayoutData="1">
            <Pin Name="OUT" Connection="L:var3" />
            <Pin Name="IN1" Connection="L:var1" />
            <Pin Name="IN2" Connection="L:var2" />
        </Block>
    </TopUserBlock>
    <F72188310901404A>AAAEBBmQ/FBiH1Yf2JOwGE/eaGCGwBSuYKw7u7F7mr6/Gar9yKZJwf8gx8XK1HZiQcGniCm+hXL+WocE3QoWBbsLNKzeVX/rCMdKn4CeNBpP6y0/r
</Program>
```

GE ToolBoxST
Blocks XML Representation

PLC Logic Transfer

DEVELOP

PLC code, or textual code, written in either LD, ST, or FBD languages.

IEC 61131-3 Source Code

COMPILE

Programs are compiled into PLC-compatible bytecode or binary code.

Proprietary Bytecode

PLC Logic Transfer

```
01F0h: 01 00 01 00 04 00 6D 61 69 6E 01 00 01 00 00 00  ......main......
0200h: 2E 00 00 01 13 00 00 06 01 00 00 07 00 00 01 00  ................
0210h: 0D 00 00 00 0A 00 01 00 01 00 96 00 40 00 02 00  ............@...
0220h: 12 00 00 04 10 00 00 04 11 00 00 04              ............
```

GE PCODE

Intermediate Bytecode

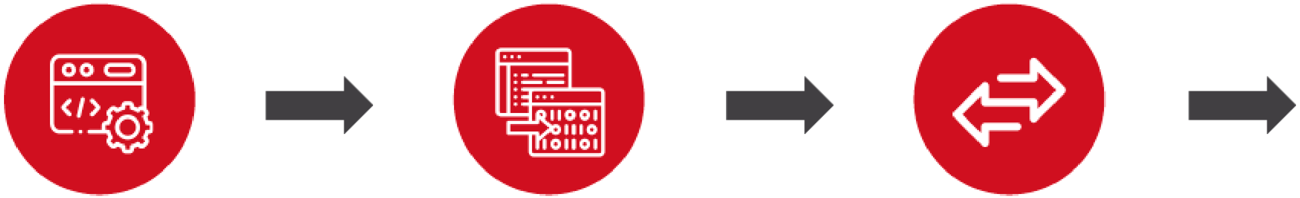
PLC Logic Transfer

pcode ADD

```
01F0h: 01 00 01 00 04 00 6D 61 69 6E 01 00 01 00 00 00   ......main......
0200h: 2E 00 00 01 13 00 00 06 01 00 00 07 00 00 01 00   ................
0210h: 0D 00 00 00 0A 00 01 00 01 00 96 00 40 00 02 00   ............@...
0220h: 12 00 00 04 10 00 00 04 11 00 00 04               ............
```

GE PCODE
Intermediate Bytecode

PLC Logic Transfer



DEVELOP

PLC code, or textual code, written in either LD, ST, or FBD languages.

IEC 61131-3 Source Code

COMPILE

Programs are compiled into PLC-compatible bytecode or binary code.

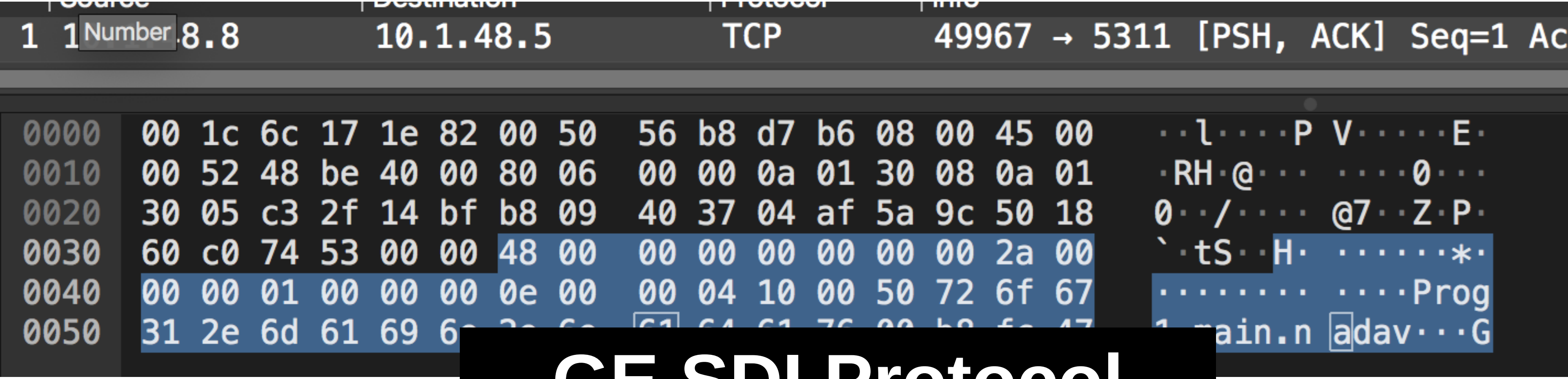
Proprietary Bytecode

TRANSFER

Compiled bytecode is transferred to the PLC.

Proprietary Protocol

PLC Logic Transfer



GE SDI Protocol

PLC Logic Transfer

DEVELOP

PLC code, or textual code, written in either LD, ST, or FBD languages.

IEC 61131-3 Source Code

COMPILE

Programs are compiled into PLC-compatible bytecode or binary code.

Proprietary Bytecode

TRANSFER

Compiled bytecode is transferred to the PLC.

Proprietary Protocol

EXECUTE

Once bytecode is successfully delivered to the PLC, the logic is repeatedly executed.

Native Machine Code

PLC Logic Transfer

```
stwu    r1, back_chain(r1)
mfcr    r12
mflr    r0
stw     r30, 0x160+var_8(r1)
mr      r30, r3
addi    r3, r1, 0x160+var_140 # set
stw     r0, 0x160+sender_lr(r1)
stw     r12, 0x160+var_40(r1)
stw     r18, 0x160+var_38(r1)
stw     r19, 0x160+var_34(r1)
stw     r20, 0x160+var_30(r1)
mr      r19, r6
stw     r21, 0x160+var_2C(r1)
stw     r22, 0x160+var_28(r1)
```

Native Machine Code

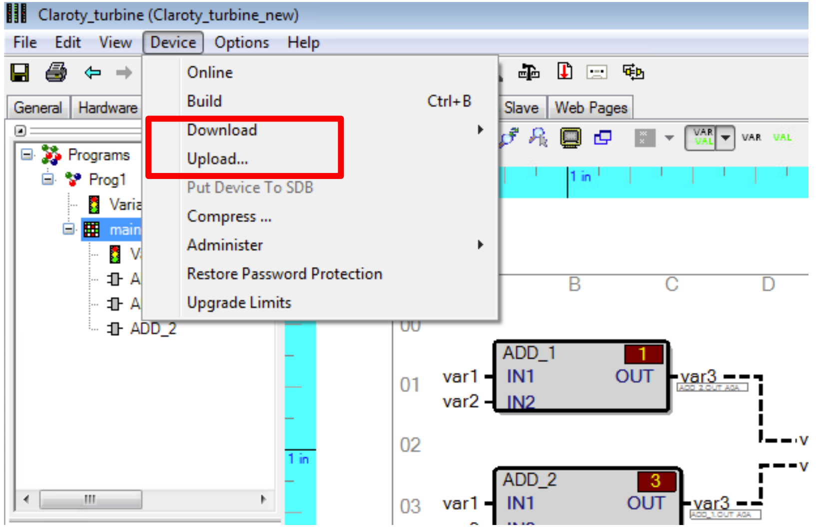
Engineering Workstation: Download, Upload

Download (new logic)

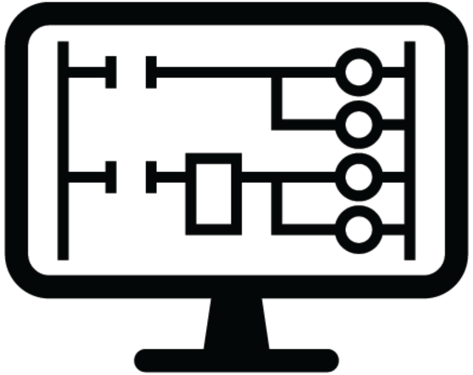
- Transfer data –**to**→ the PLC

Upload (diagnostics)

- Transfer data ←**from**– the PLC



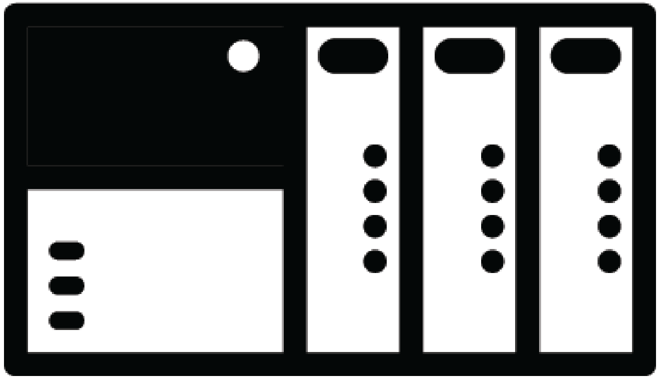
Full Download Procedure



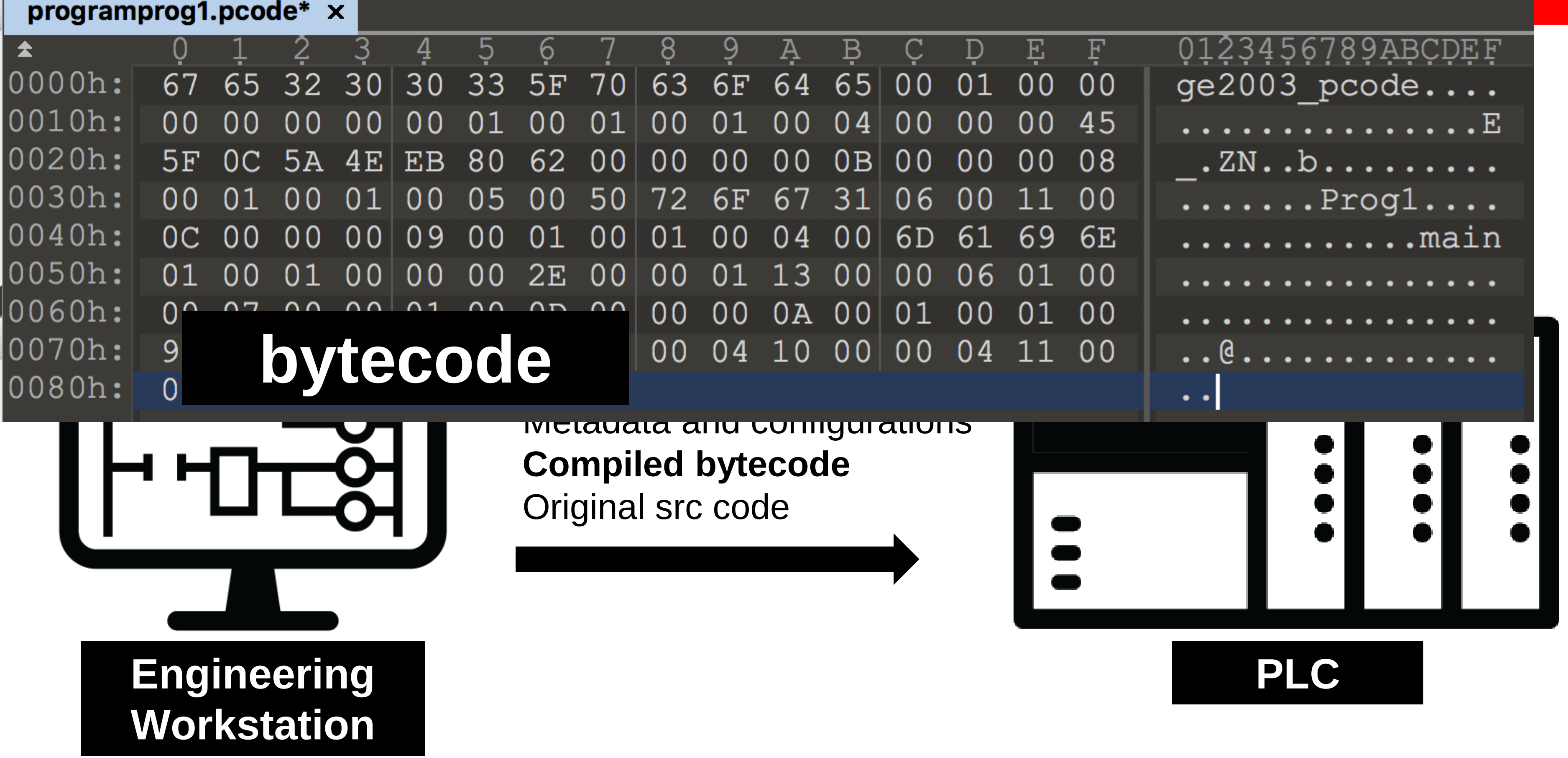
Engineering Workstation

Download Procedure

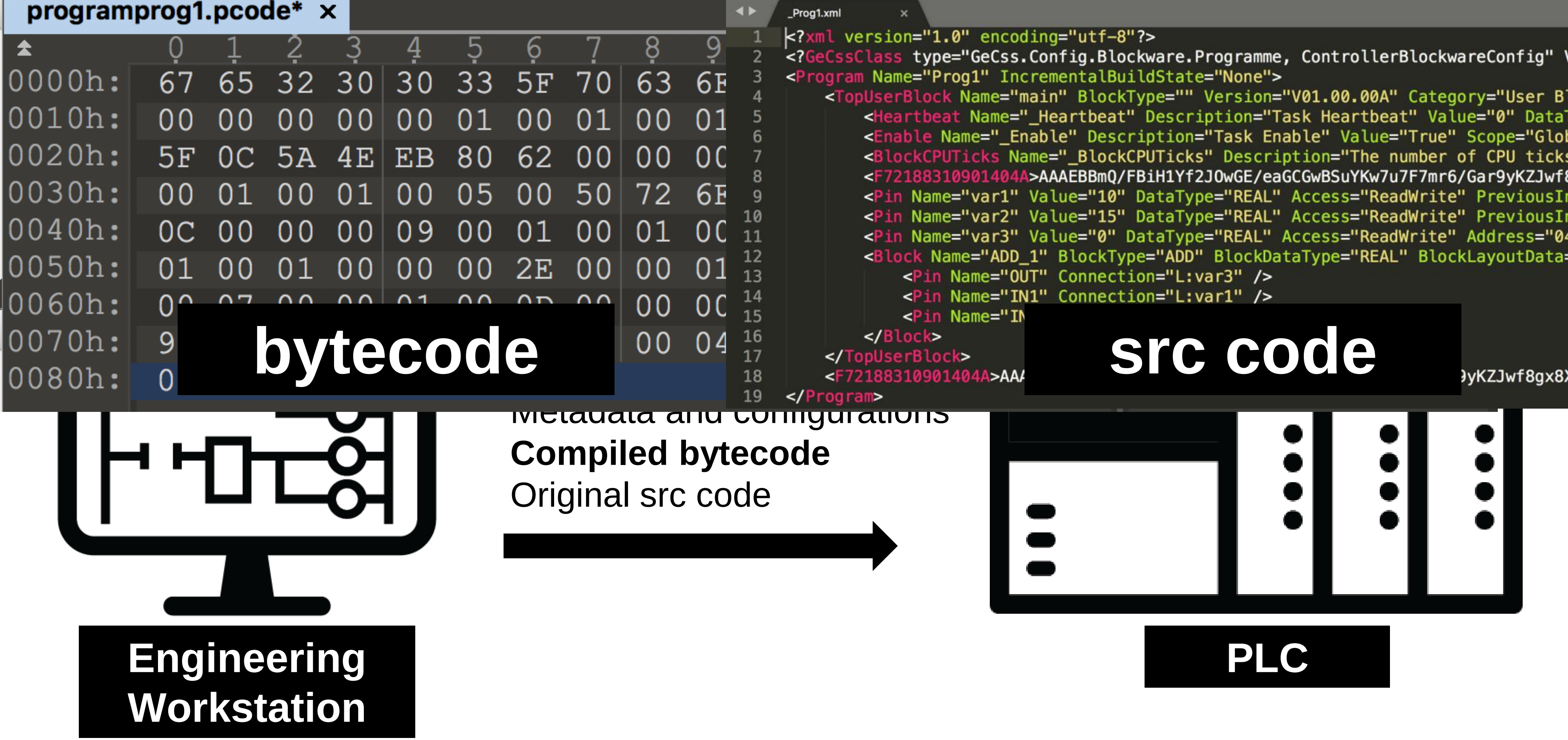
Metadata and configurations
Compiled bytecode
Original src code

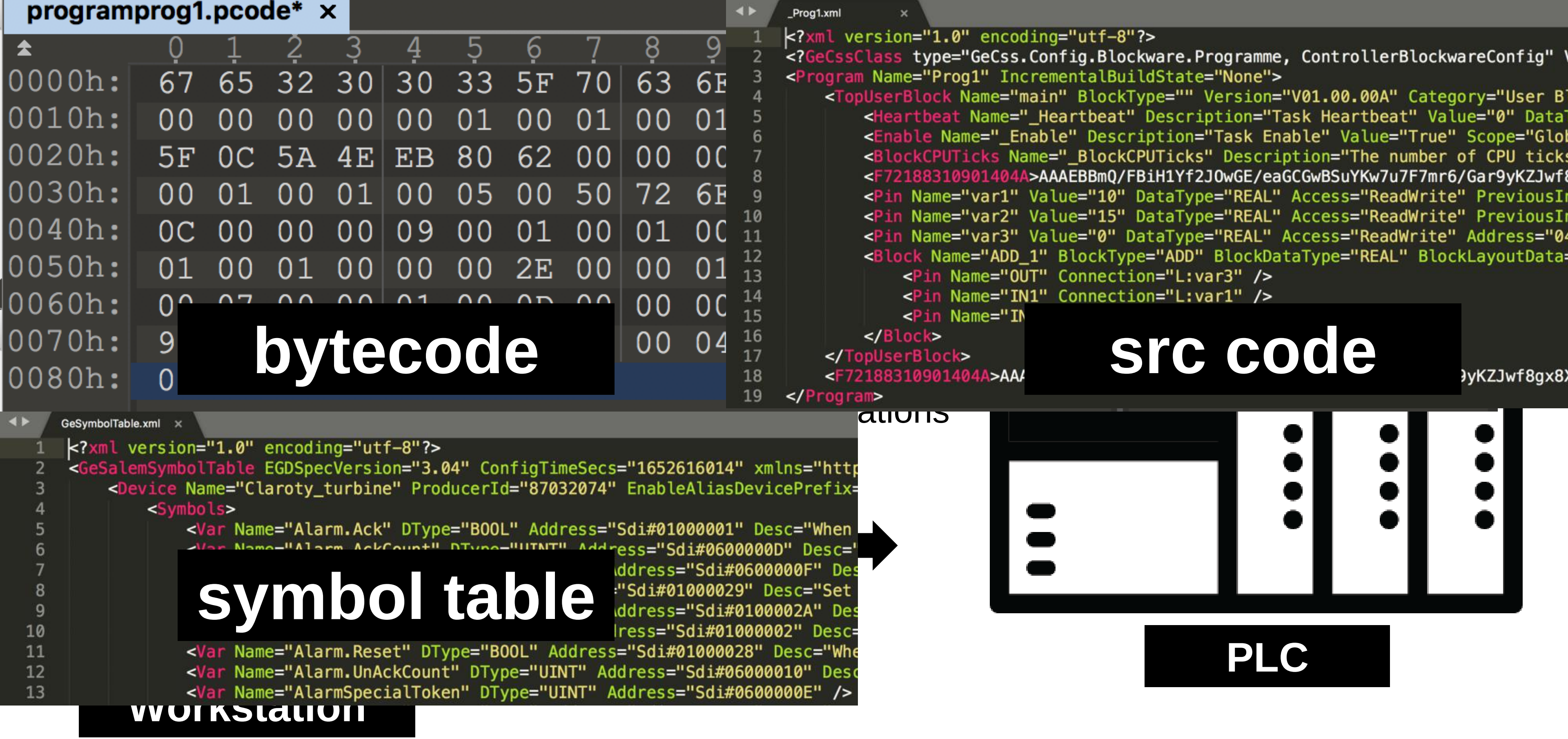


PLC



programprog1.pcode*
0 1 2 3 4 5 6 7 8 9 A B C D E F 0123456789ABCDEF
0000h: 67 65 32 30 30 33 5F 70 63 6F 64 65 00 01 00 00 ge2003_pcode....
0010h: 00 00 00 00 00 01 00 01 00 01 00 04 00 00 00 45 ....E
0020h: 5F 0C 5A 4E EB 80 62 00 00 00 00 0B 00 00 00 08 _.ZN..b.........
0030h: 00 01 00 01 00 05 00 50 72 6F 67 31 06 00 11 00 ....Prog1....
0040h: 0C 00 00 00 09 00 01 00 01 00 04 00 6D 61 69 6E ....main
0050h: 01 00 01 00 00 00 2E 00 00 01 13 00 00 06 01 00 ....
0060h: 00 00 0A 00 01 00 01 00 ....
0070h: 9 00 04 10 00 00 04 11 00 ..@.............
0080h: 0 ..
bytecode
Compiled bytecode
Original src code
Engineering Workstation
PLC


programprog1.pcode*
_Prog1.xml
bytecode
src code
Compiled bytecode
Original src code
Engineering Workstation
PLC

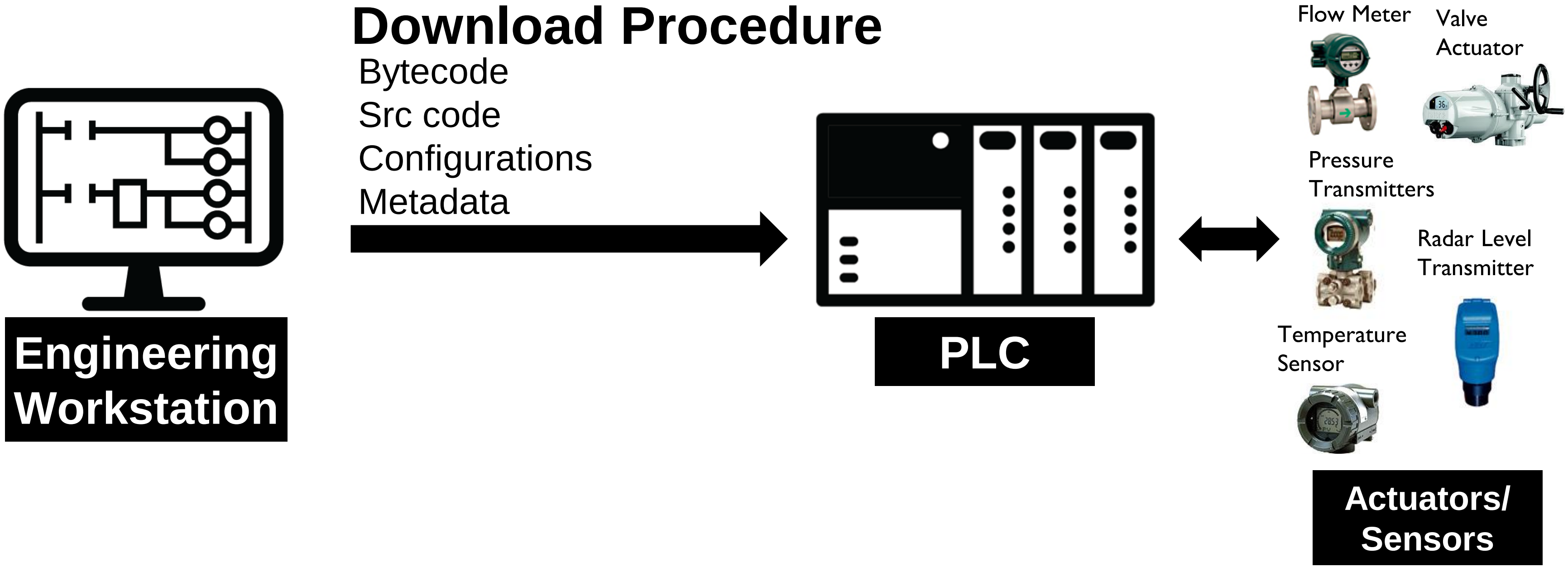

programprog1.pcode*
bytecode
_Prog1.xml
<?xml version="1.0" encoding="utf-8"?>
<?GeCssClass type="GeCss.Config.Blockware.Programme, ControllerBlockwareConfig"
<Program Name="Prog1" IncrementalBuildState="None">
<TopUserBlock Name="main" BlockType="" Version="V01.00.00A"
<Heartbeat Name="_Heartbeat" Description="Task Heartbeat" Value="0"
<Enable Name="_Enable" Description="Task Enable" Value="True"
<BlockCPUTicks Name="_BlockCPUTicks" Description="The number of CPU
<Pin Name="var1" Value="10" DataType="REAL" Access="ReadWrite"
<Pin Name="var2" Value="15" DataType="REAL" Access="ReadWrite"
<Pin Name="var3" Value="0" DataType="REAL" Access="ReadWrite"
<Block Name="ADD_1" BlockType="ADD" BlockDataType="REAL"
<Pin Name="OUT" Connection="L:var3" />
<Pin Name="IN1" Connection="L:var1" />
</Block>
</TopUserBlock>
</Program>
src code
GeSymbolTable.xml
<?xml version="1.0" encoding="utf-8"?>
<GeSalemSymbolTable EGDSpecVersion="3.04" ConfigTimeSecs="1652616014"
<Device Name="Claroty_turbine" ProducerId="87032074"
<Symbols>
<Var Name="Alarm.Ack" DType="BOOL" Address="Sdi#01000001"
<Var Name="Alarm.Reset" DType="BOOL" Address="Sdi#01000028"
<Var Name="Alarm.UnAckCount" DType="UINT" Address="Sdi#06000010"
<Var Name="AlarmSpecialToken" DType="UINT" Address="Sdi#0600000E" />
symbol table
PLC


programprog1.pcode*
bytecode
_Prog1.xml
src code
GeSymbolTable.xml
symbol table
DistributedIO.Xml
I/O conf
PLC

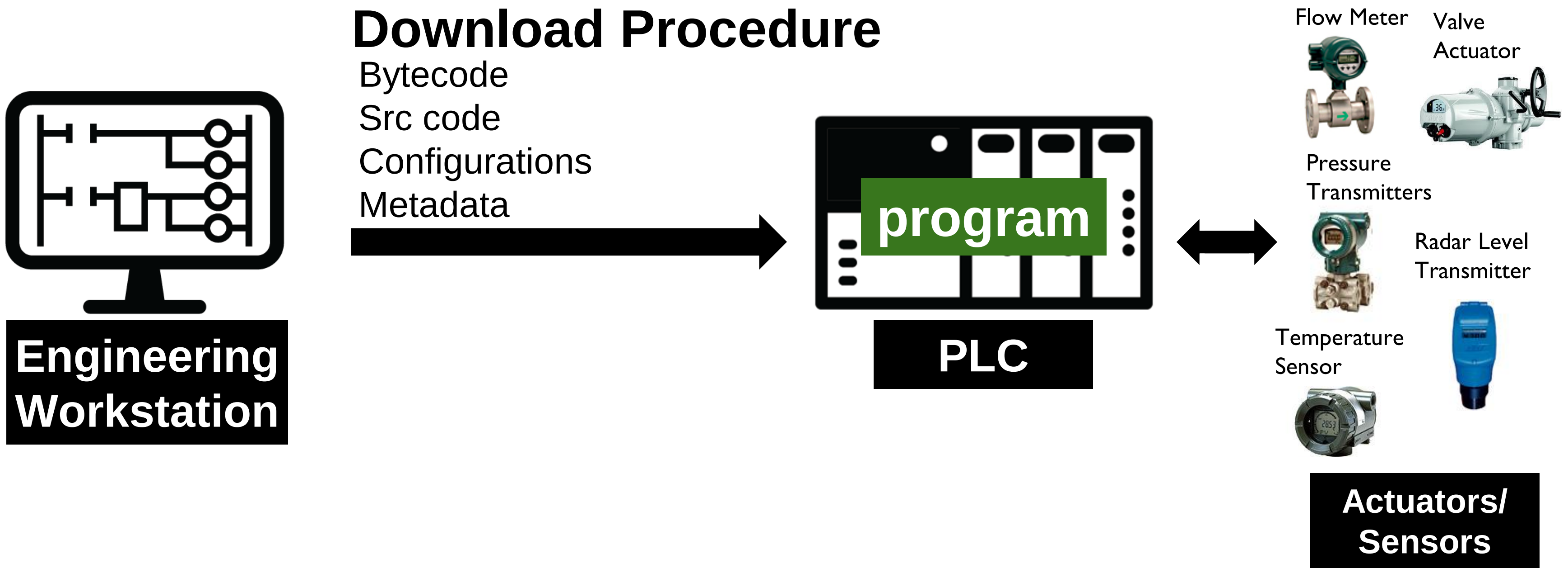

programprog1.pcode*
bytecode
_Prog1.xml
src code
GeSymbolTable.xml
symbol table
DistributedIO.xml
I/O conf
PLC
Device.xml
device conf


programprog1.pcode*
bytecode
_Prog1.xml
src code
GeSymbolTable.xml
symbol table
DistributedIO.Xml
I/O conf
Device.xml
device conf
vardef.pcode
variable def

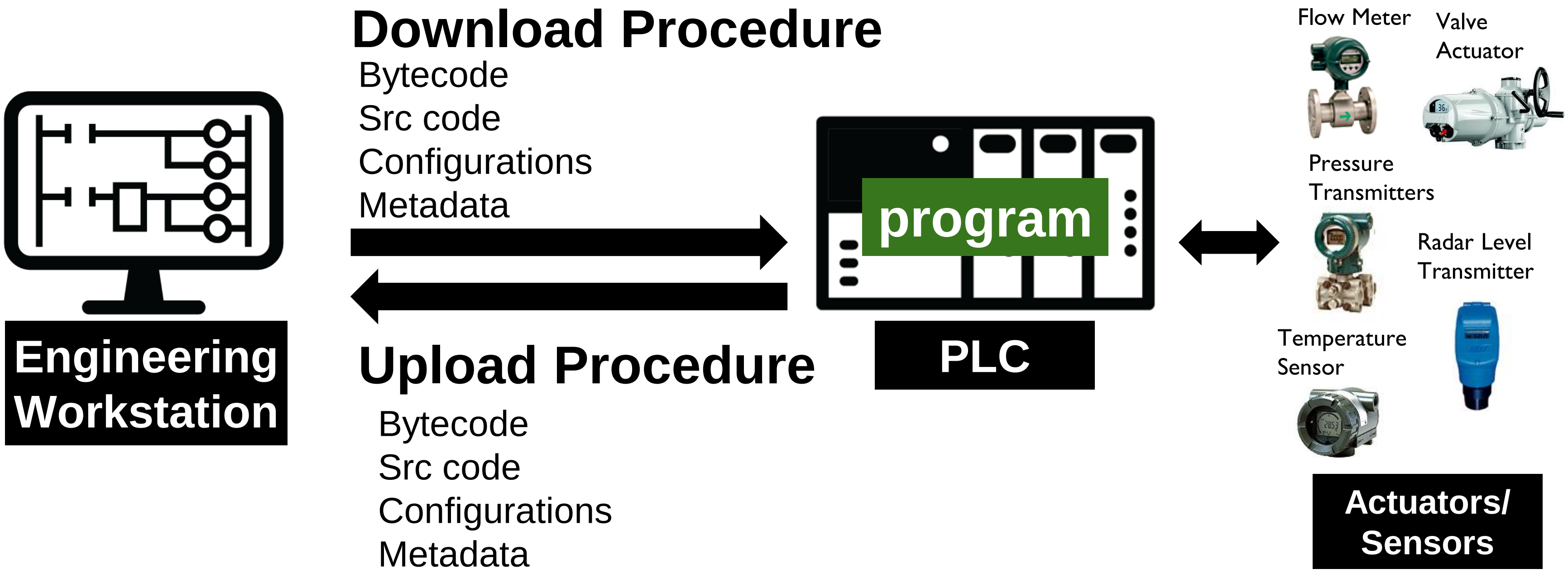
Download/Upload Procedures



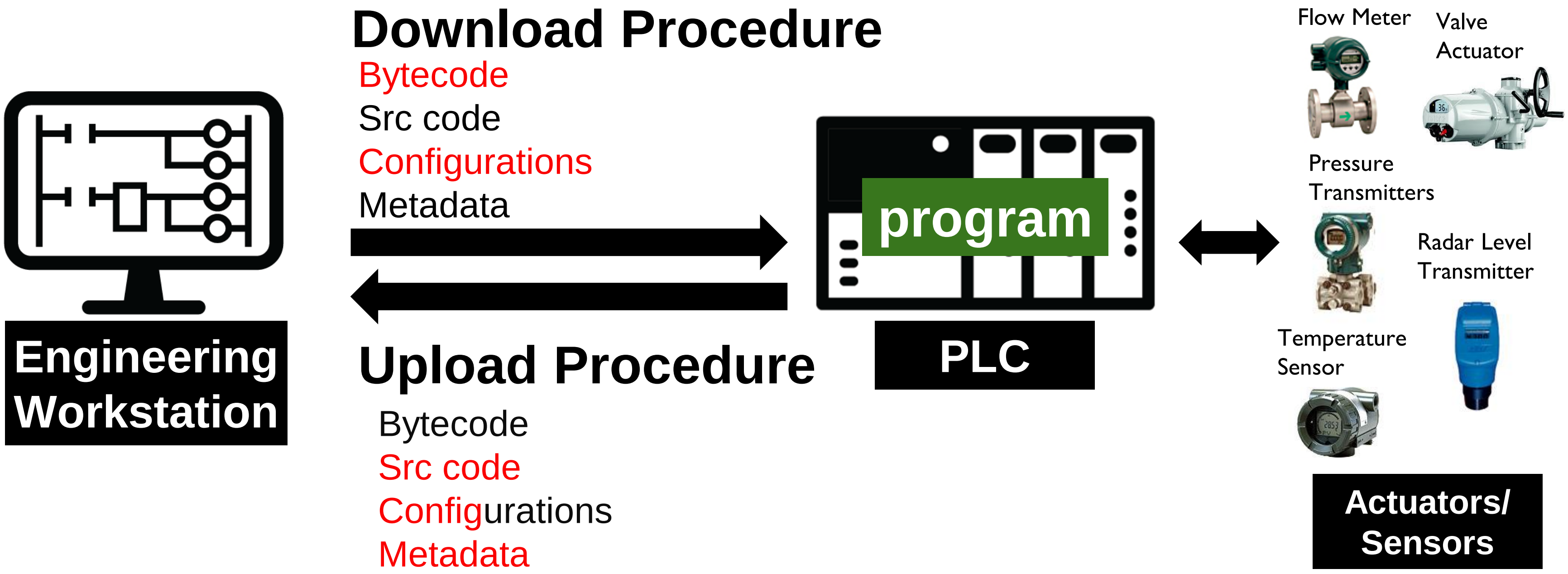
Download/Upload Procedures



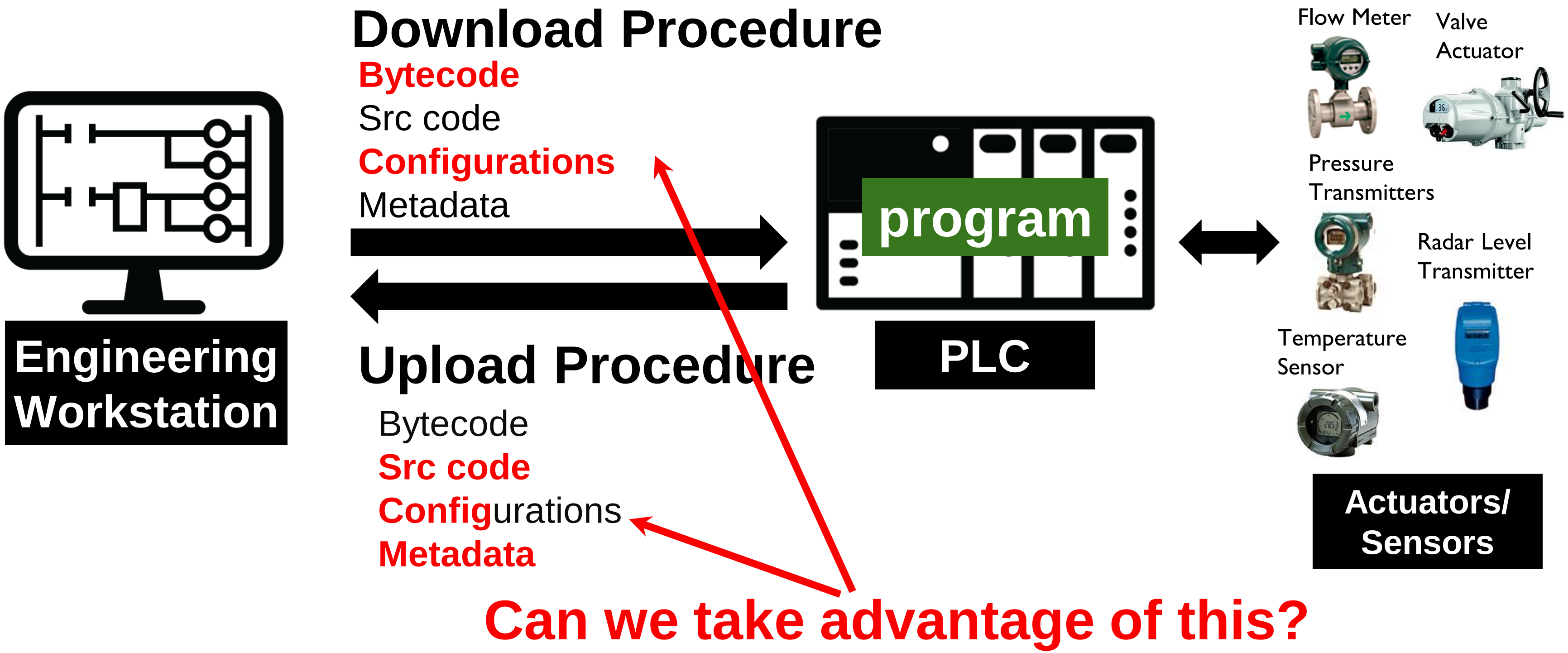
Download/Upload Procedures



Download/Upload Procedures



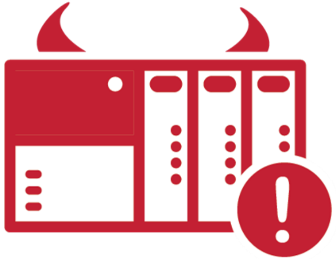
Download/Upload Procedures



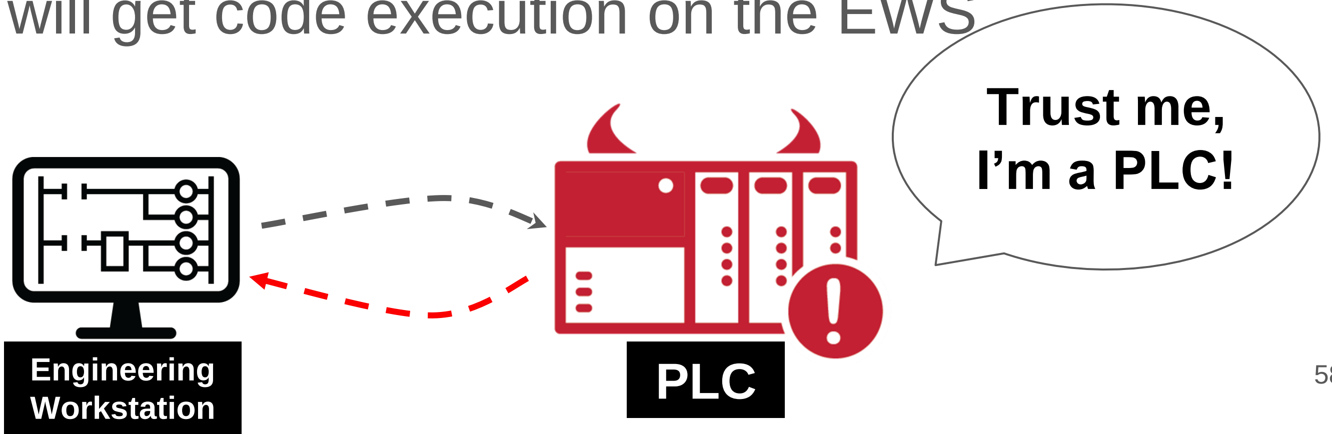
Agenda

- Motivation
- PLC Download & Upload Procedures
- **Evil PLC Attack**

Evil PLC Attack



- Let’s store malicious data objects on the PLC
- The PLC is weaponized but left unaffected and operational
- Upon EWS Upload the data will trigger a parsing/logic vuln
- And we will get code execution on the EWS



Our Research

- Seven industry leading ICS vendors

ebay Shop by category

Xinje PLC

Back to search results | Listed in category: Business & Industrial > Industrial Automation & Motion Controls > Control Systems & PLCs > PLC Processors

1pcs Used XINJE PLC XC5-60T-E

Condition: **Used**

Quantity: 1 5 available

Price: **GBP 164.09**

Approximately ILS 676.79

Best Offer:

Shipping: **GBP 11.34** (approx ILS 46.77) Stan

International shipment of items may b

charges.

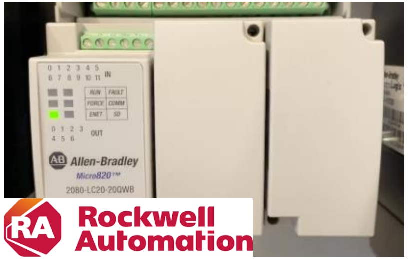
Located in: China, China

Our Research

- Seven industry leading ICS vendors
  - **Setup & Testbed**
  - Upload/Download mechanism
    - RE the EWS, PLC firmware
    - Analyze the proprietary protocol
  - What's stored on the PLC + retrieved & parsed by the EWS
  - Find a vulnerability in the parsing flow

Our Research

- Seven industry leading ICS vendors
  - Setup & Testbed
  - **Upload/Download mechanism**
    - **RE the EWS, PLC firmware**
    - **Analyze the proprietary protocol**
  - What’s stored on the PLC + retrieved & parsed by the EWS
  - Find a vulnerability in the parsing flow

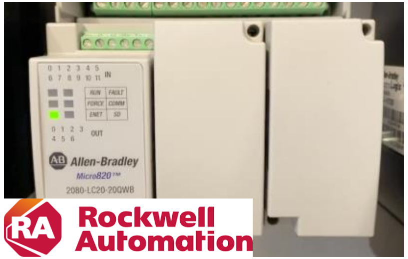



Our Research

- Seven industry leading ICS vendors
  - Setup & Testbed
  - Upload/Download mechanism
    - RE the EWS, PLC firmware
    - Analyze the proprietary protocol
  - **What’s stored on the PLC + retrieved & parsed by the EWS**
  - Find a vulnerability in the parsing flow

Our Research

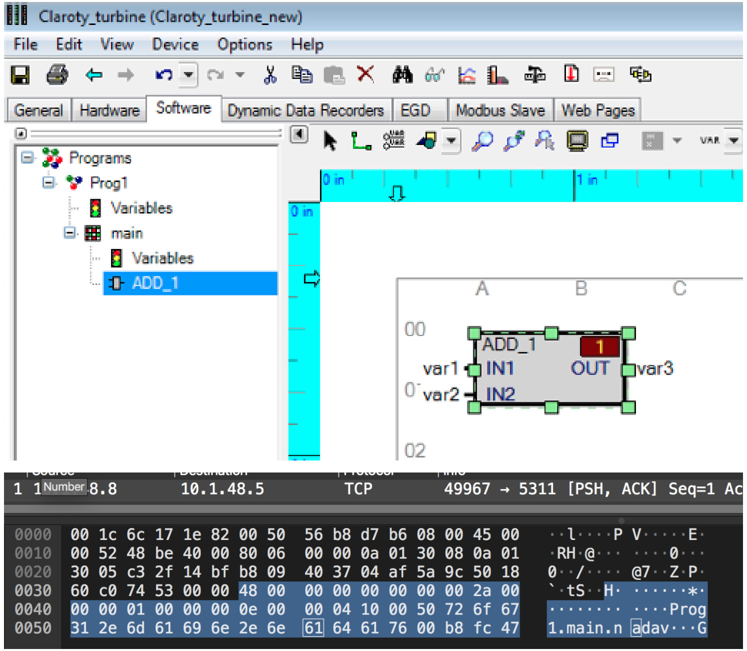
- Seven industry leading ICS vendors
    - Setup & Testbed
    - Upload/Download mechanism
        - RE the EWS, PLC firmware
        - Analyze the proprietary protocol
    - What's stored on the PLC + retrieved & parsed by the EWS
    - **Find a vulnerability in the parsing flow**

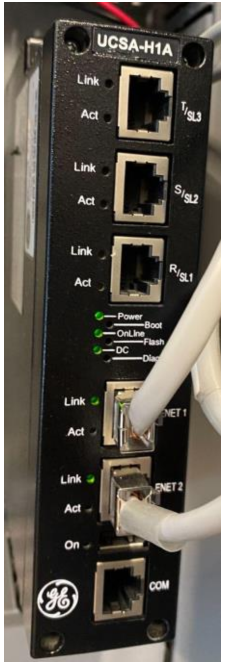


Vendor	Platform	EWS	Protocol	CVE
OVARRO	TBOX	TwinSoft	Custom Modbus (Port 502/TCP)	Advisory CVE-2021-22650
B&R (ABB)	X20 System	Automation Studio	ANSL (Port 11169/TCP) INA2000 (Port 11159/UDP)	Advisory CVE-2021-22289
Schneider Electric	Modicon (M340, M580)	EcoStruxure Control Expert (Unity Pro)	Modbus/UMAS (Port 502/TCP)	Advisory CVE-2022-26507
General Electric (GE)	Mark VIe	ToolBoxST	SDI (Port 5311/TCP)	GE Advisory ICS-CERT advisory CVE-2021-44477 CVE-2018-16202
Rockwell Automation	Micro Control Systems	Connected Components Workbench (CCW)	CIP (Port 44818/TCP)	Advisory CVE-2021-27475 CVE-2021-27471 CVE-2021-27473
Emerson	PACSystems	PAC Machine Edition	SRTP (Port 18245/TCP)	Advisory CVE-2022-2788
Xinje	XDPPro	XD PLC Program Tool	Modbus UDP (Port 502/UDP)	Advisory CVE-2021-34605 CVE-2021-34606

Example: GE Mark VIe

- **Platform**: Mark VIe (PPC BE)
- **RTOS**: QNX Neutrino
- **EWS**: ToolBoxST (C#)
- **Protocol**: SDI (TCP port 5311)





What’s Stored on the Controller

- **Binary code**: `programprog1.pcode`
  - Used by the controller, MarkVIe, to execute the logic code (bytecode).
- **Source code**: `device.zip` → `_Prog1.xml`
  - Used by the engineering workstation, ToolboxST, to show the engineer what code is running on the controller.

Filename	Filesize	Filetype
..		
alarms.pcode	101	pcode-file
commandeventlog.pcode	12157	pcode-file
ddr.pcode	82	pcode-file
device.zip	23644	ZIP archive
device.zip.crc	4	crc-file
dhcpd.conf	337	conf-file
egd-gesymboltable.cxml	6575	cxml-file
egd-guidevice.xml	1395	XML
egd-outputs.xml	3847	XML
egd-profile.xml	976	XML
egd-symboltable.xml	12530	XML
hart.xml	108	XML
hosts	180	File
ntp.conf	115	conf-file
ntpionet.conf	115	conf-file
nvram.pcode	69	pcode-file
platform.pcode	67	pcode-file
profibus.xml	112	XML
programprog1.pcode	556	pcode-file
redsymboltable.pcode	57	pcode-file
requisitioninfo.xml	314	XML
scheduler.pcode	499	pcode-file
ssif.pcode	63	pcode-file
sysinit.pcode	125	pcode-file
system.pcode	545	pcode-file
vardef.pcode	512	pcode-file

EWS Upload Flow

ploadFromControllerProgress

```
internal bool DoUpload()
{
    this.m_UploadedFileName = FileUtils.GetTempFileName();
    File.Delete(this.m_UploadedFileName);
    try
    {
        this.Descriptor.Name = Path.GetFileNameWithoutExtension(this.m_UploadedFileName)
        this.m_TempDevice = (IMarkVIeSDevice)this.Sys.AddDevice(this.Descriptor);
        this.m_TempDevice.DeviceConnection.IPAddress = this.Wizard.UploadFromIpAddress;
        ICommandReturn ret = this.m_TempDevice.DeviceConnection.Cmd.ReadFile(this.m_Path
          this.m_UploadProgressBar);
        if (!ret.OK)
```

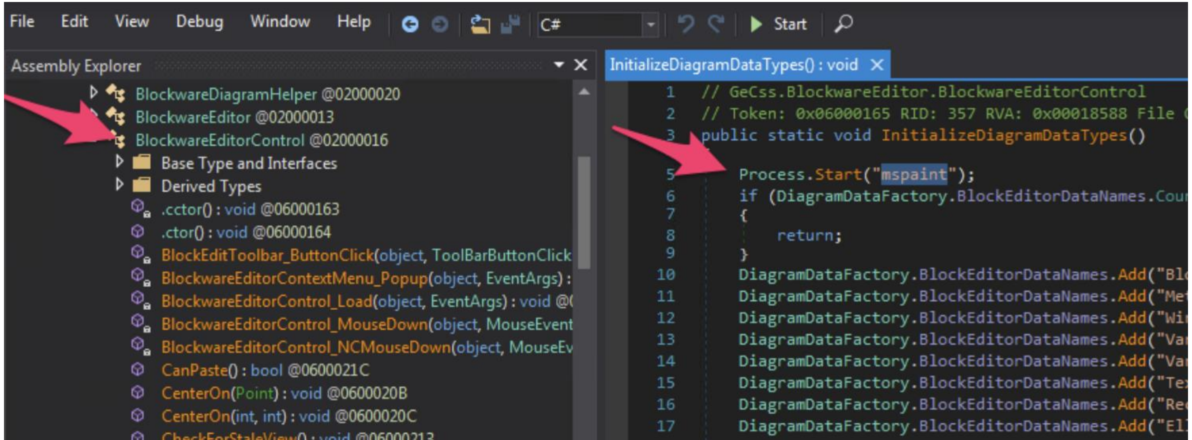
Vulnerability - Zip Slip

```
using (Ionic.Zip.ZipFile zipFile = new Ionic.Zip.ZipFile(srcFilePath))
{
    foreach (Ionic.Zip.ZipEntry zipEntry in zipFile)
    {
        try
        {
            if (!skipZeroSizeFiles || zipEntry.UncompressedSize != 0L)
            {
                string targetDir = destDirectory;
                if (fileIncludeHandler(zipEntry.FileName, zipEntry.UncompressedSize, ref targetDir))
                {
                    zipEntry.Extract(targetDir, extAction);
                    if (postFileExtractHandler != null)
                    {
                        targetDir = destDirectory;
                        postFileExtractHandler(zipEntry.FileName, zipEntry.UncompressedSize, ref targetDir);
```

- ../../../../../../../File/To/Overwrite

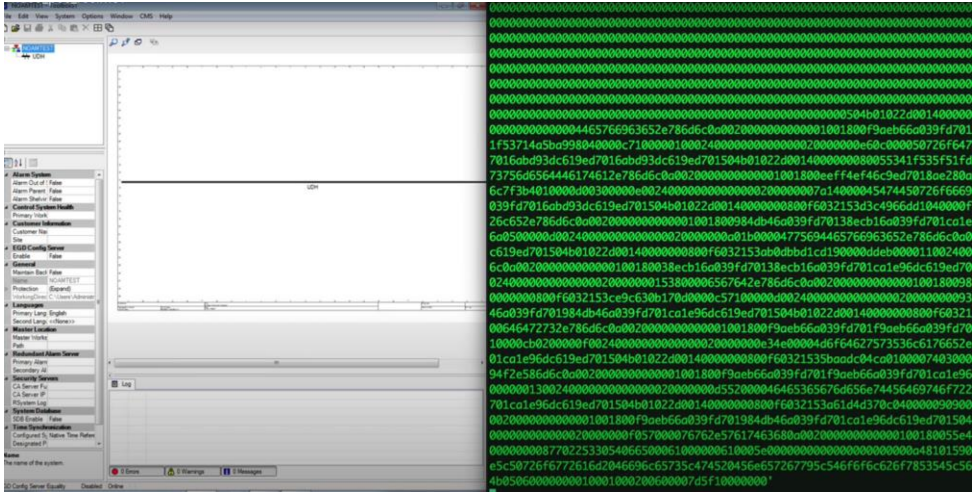
Preparing the Payload

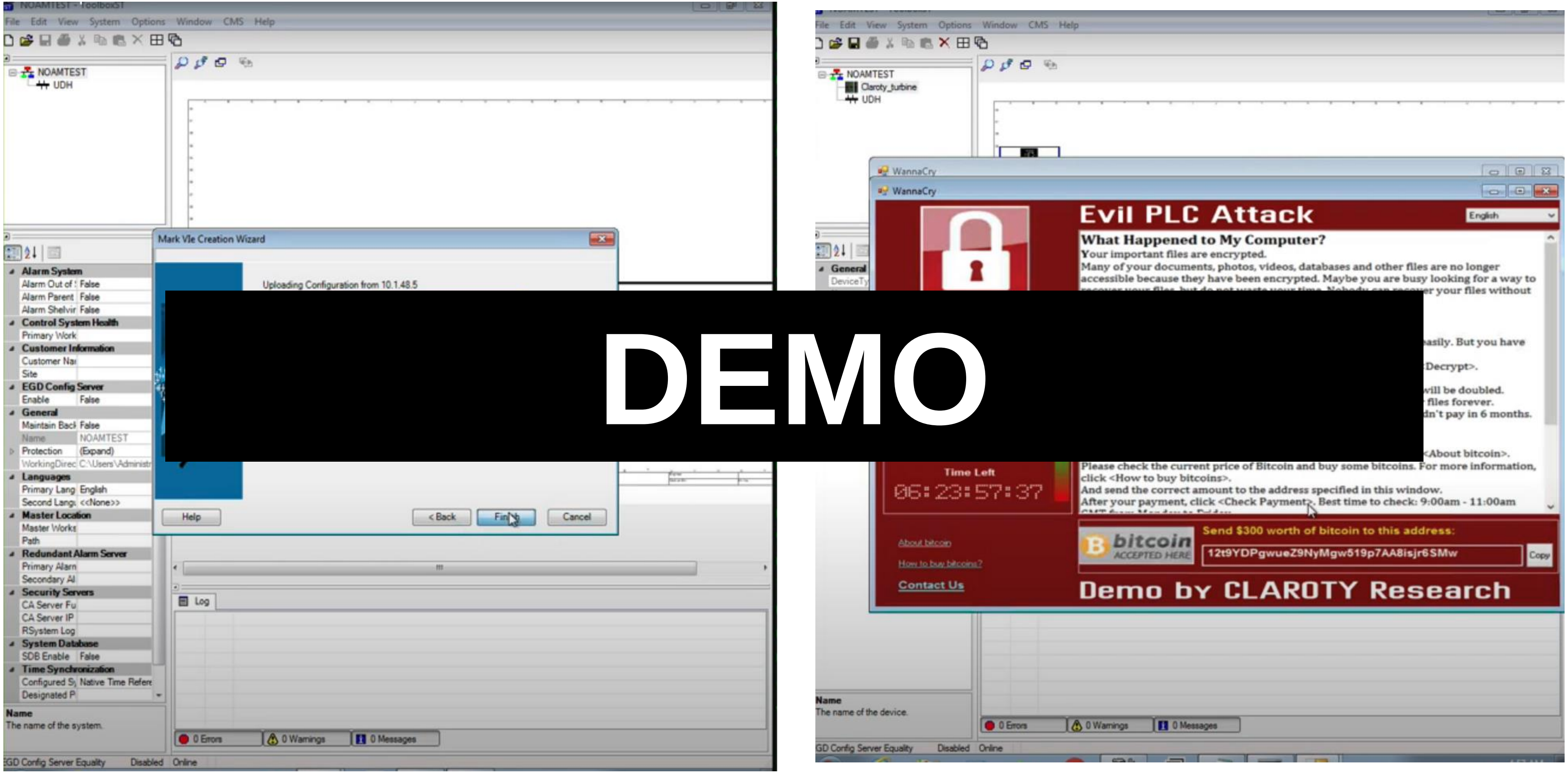
- Patching CIL code in `BlockwareEditor.dll` is a good target because the DLL is loaded immediately after an upload procedure
- Infected `device.zip` (ZipSlip)



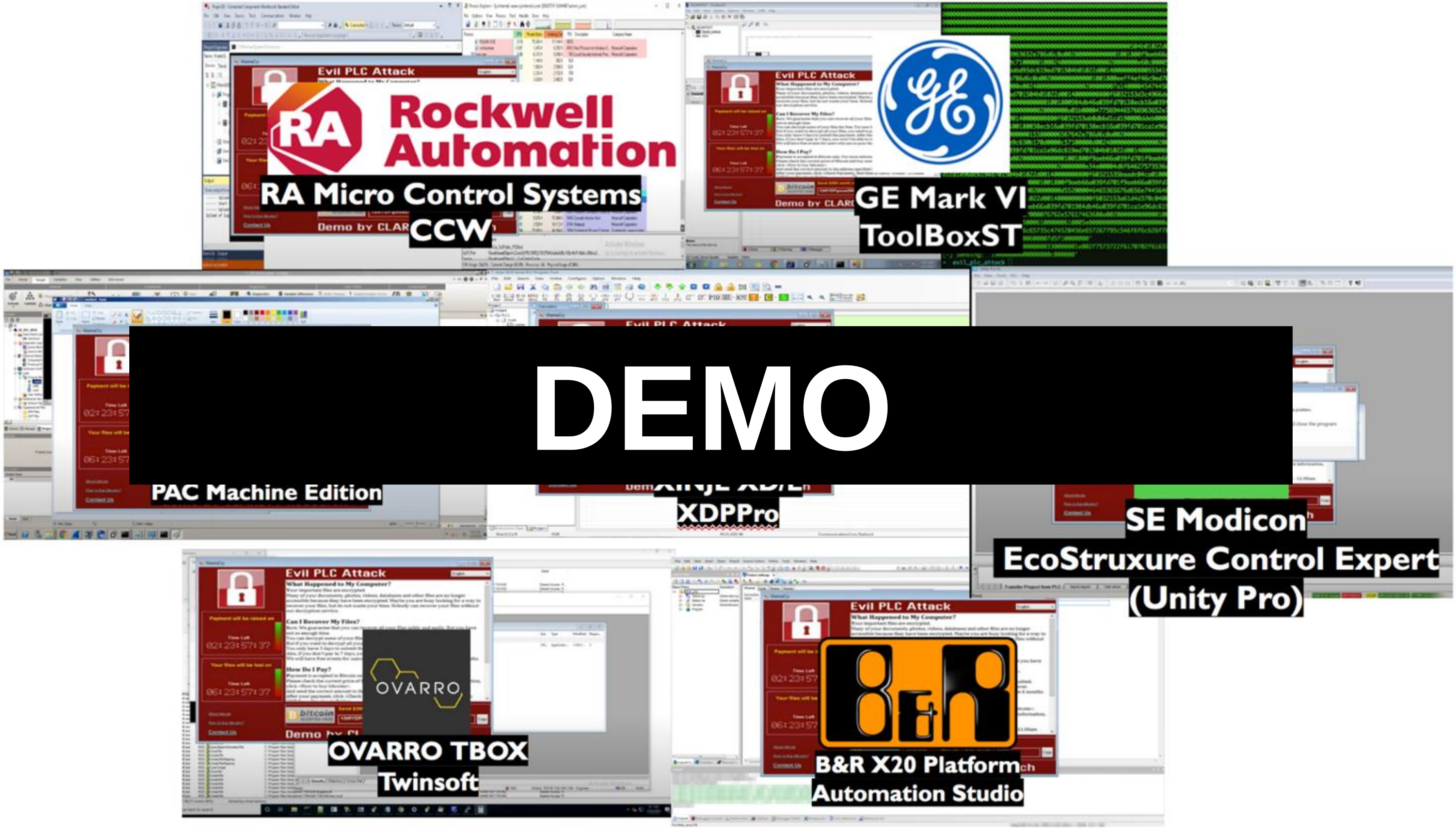
Weaponize the Controller

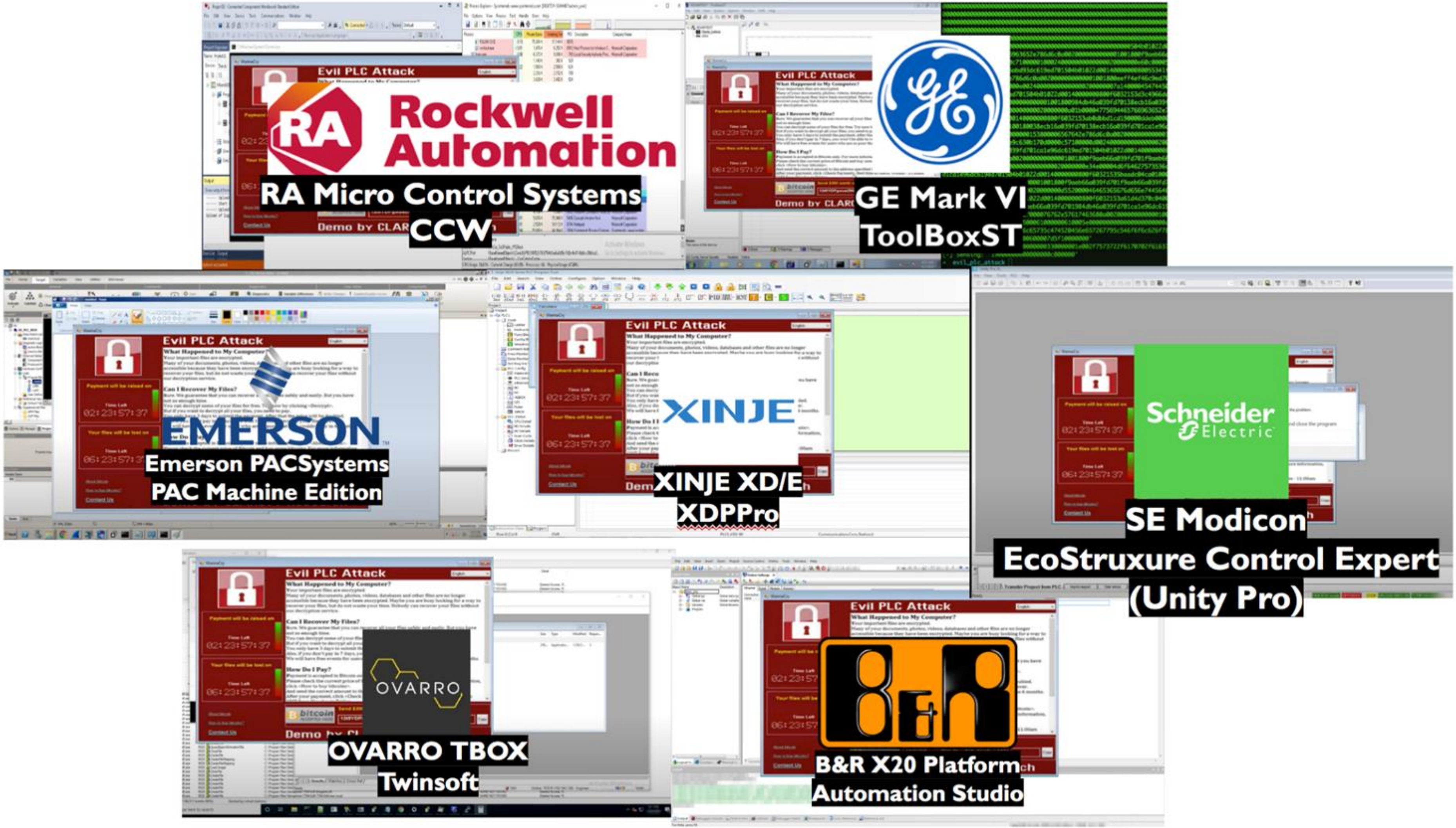
- Implement the full SDI protocol
  - SDI commands **0x18, 0x19** to start the download procedure
  - SDI command **0x0d** to write the malicious archive




DEMO
NOAMTEST - ToolboxST
File Edit View System Options Window CMS Help
Mark VIe Creation Wizard
Uploading Configuration from 10.1.48.5
Help
< Back
Finish
Cancel
Log
0 Errors
0 Warnings
0 Messages
WannaCry
Evil PLC Attack
What Happened to My Computer?
Your important files are encrypted.
Time Left
06:23:57:37
Send $300 worth of bitcoin to this address:
12t9YDPgwueZ9NyMgw519p7AA8isjr6SMw
About bitcoin
How to buy bitcoins?
Contact Us
Demo by CLAROTY Research

Vendor	Platform	Arch	Tested Model (CPU Module)	RTOS Firmware	Engineering Workstation	Protocol	Root Cause	CVE
OVARRO	TBOX	ARM	TBOX LT2-530	Linux	TwinSoft	Custom Modbus (Port 502/TCP)	ZipSlip / Path Traversal	Advisory **CVE-2021-22650**
B&R (ABB)	X20 System	ARM/x86	X20CP1585	VxWorks	Automation Studio	ANSL (Port 11169/TCP) INA2000 (Port 11159/TCP or UDP)	ZipSlip / Path Traversal	Advisory **CVE-2021-22289**
Schneider Electric	Modicon (M340, M580)	ARM	M340, M580	VxWorks	EcoStruxure Control Expert (Unity Pro)	Modbus/UMAS (Port 502/TCP)	Memory Corruption (Heap overflow)	Advisory **CVE-2022-26507**
General Electric (GE)	Mark VIe	PPC (BE)	Mark VIe IS220UCSAH1A	QNX Neutrino	ToolBoxST	SDI (Port 5311/TCP)	ZipSlip / Path Traversal	Advisory **CVE-2021-44477** **CVE-2018-16202**
Rockwell Automation	Micro Control Systems	ColdFire	Micro820	ThreadX	Connected Components Workbench (CCW)	CIP (Port 44818/TCP)	Unsafe Deserialization	Advisory **CVE-2021-27475** **CVE-2021-27471** **CVE-2021-27473**
Emerson	PACSystems	x86	Rx3i	VxWorks	PAC Machine Edition	SRTP (Port 18245/TCP)	ZipSlip / Path Traversal	Advisory **CVE-2022-2788**
Xinje	XDPPro	ARM	XD/E PLC	VxWorks	XD PLC Program Tool	Modbus UDP (Port 502/UDP)	ZipSlip / Path Traversal	Advisory **CVE-2021-34605** **CVE-2021-34606**


Rockwell Automation
RA Micro Control Systems
CCW
Evil PLC Attack
GE Mark VI
ToolBoxST
DEMO
PAC Machine Edition
XDPPro
SE Modicon
EcoStruxure Control Expert
(Unity Pro)
OVARRO
OVARRO TBOX
Twinsoft
B&R X20 Platform
Automation Studio


Evil PLC Attack
Rockwell Automation
RA Micro Control Systems
CCW
GE Mark VI
ToolBoxST
EMERSON
Emerson PACSystems
PAC Machine Edition
XINJE
XINJE XD/E
XDPPro
Schneider Electric
SE Modicon
EcoStruxure Control Expert
(Unity Pro)
OVARRO
OVARRO TBOX
Twinsoft
B&R X20 Platform
Automation Studio

Evil PLC Attack

Q&A

claroty.com/team82

Evil PLC Attack

FIN

claroty.com/team82